CYBERSECURITY RISK ASSESSMENT AND RANSOMWARE RESILIENCE STRATEGY FOR A MULTI-SITE HEALTHCARE PROVIDER

Programme: Certified Cybersecurity Consultant (CSCC), Cohort 11
Course: CCC104 – Capstone Project
Academic Period: 2026 | Level 1 | Semester 2
Project ID: CAP-20261022-E1E80DDE52
Consultancy Base: Simulated Nigerian Private Healthcare Provider
Facilities: FAC-A (Main Facility) and FAC-B (Satellite Facility)

Prepared By: Consultative Capstone Team (Cohort 11)

Submission Date: Thursday 7, November 2026

DECLARATION AND SUBMISSION DETAILS

We hereby declare that this consultancy capstone report represents the collaborative work undertaken by the project team under the Certified Cybersecurity Consultant (CSCC) programme.

The assessment, risk evaluations, security architecture designs, laboratory demonstrations and implementation recommendations were developed within approved academic boundaries. Practical laboratory exercises were conducted in an isolated testing environment using synthetic business data and locally created test accounts.

The case organisation is simulated, and its operational and technical characteristics are based on defined project assumptions. Laboratory results are reported only to the extent supported by the recorded testing evidence.

Workstream Ownership and Submissions

Team Member	Registration Number	Assigned Responsibility
Alphonsus Stephen Chibuike	C11/26/CSCC/17451	Team Lead and Governance Coordinator
Laban Emmanuel Rakum	C11/26/CSCC/17472	Assessment and NIST CSF Lead
Nicholas Atacha	C11/26/CSCC/17395	Risk Assessment Lead
Oreofe Dada	C11/26/CSCC/17383	Security Architecture Lead
Owiliwa Clever Goodluck	C11/26/CSCC/17416	Technical Validation and Backup Recovery Lead
Oyewale Akinrinde	C11/26/CSCC/17529	Incident Response, Roadmap and Dashboard Lead

ACKNOWLEDGEMENTS

We express our sincere appreciation to our programme supervisor, technical facilitators and academic mentors for their guidance, constructive feedback and support throughout the development of this consultancy project.

We also acknowledge the contributions of every team member in the development of the assessment baseline, cybersecurity risk register, security architecture, laboratory demonstrations, incident response arrangements and management planning documents.

Their collective efforts contributed to the successful development of this consultancy deliverable.

EXECUTIVE SUMMARY

This consultancy report presents a cybersecurity risk assessment, target security architecture and 90-day ransomware resilience strategy for a simulated Nigerian private healthcare provider operating across two facilities: Facility A (FAC-A Main Facility) and Facility B (FAC-B Satellite Facility).

The organisation is assumed to depend on interconnected digital infrastructure for Electronic Health Records (EHR), patient registration, appointment scheduling, billing, internal communication and administrative operations. These dependencies create potential exposure to ransomware and other cybersecurity incidents, particularly where access management, endpoint protection, network segmentation, security monitoring and backup arrangements are insufficient.

The project adopts the National Institute of Standards and Technology Cybersecurity Framework (NIST CSF) 2.0 as its primary assessment framework, supported by NIST SP 800-30 Rev. 1 for cybersecurity risk assessment and NIST SP 800-207 for Zero Trust Architecture principles.

The assessment established a master inventory of 50 assets across nine functional categories and developed a canonical register of 15 cybersecurity risks (`R01–R15`). The identified threat scenarios include phishing and credential theft, excessive privileges, administrator account compromise, delayed security updates, inadequate endpoint protection, insufficient network segmentation, weak security monitoring, backup compromise and uncontrolled remote access.

A target security architecture was developed across seven technical domains, incorporating identity and access management, endpoint security, network segmentation, centralised monitoring, vulnerability management, third-party access governance and backup protection. The proposed network architecture uses seven logical security zones (`Z1–Z7`) to strengthen isolation and restrict unnecessary communication between critical systems.

Selected security controls were demonstrated in an isolated Windows 11 laboratory environment using synthetic healthcare-related data. The practical exercises included local role-based access control testing, Windows process-creation auditing with command-line logging, and backup restoration with SHA-256 cryptographic hash verification. The access control exercise recorded nine successful expected access decisions, while the restoration exercise verified matching hashes for three restored synthetic files. These results demonstrate the tested controls within the laboratory environment and do not constitute production-system validation.

Operational preparedness was examined through Operation DryRUN, a discussion-based ransomware tabletop exercise conducted on 28 October 2026. The exercise identified ten procedural gaps (`G1–G10`) and generated eight corrective actions (`R1–R8`) for integration into the improvement roadmap.

The proposed implementation programme is structured into three phases:

1. **Phase 1 – Stabilise and Assign:** Address critical exposures, strengthen privileged access, remove direct internet-facing RDP and isolate backup credentials.
2. **Phase 2 – Visibility and Verification:** Improve endpoint protection, centralise security monitoring, implement network segmentation and strengthen third-party access governance.
3. **Phase 3 – Prove and Embed:** Complete priority infrastructure modernisation, conduct recovery validation, reassess residual risks and establish management reporting.

The estimated cash requirement is **₦26,795,000**, inclusive of a 15% contingency. The annual recurring software subscription component is estimated at **₦8,340,000**, while absorbed internal labour is valued separately at **₦3,600,000**. The resulting estimated full economic cost is ₦30,395,000.

A management dashboard comprising 12 key performance indicators (KPIs) is proposed to monitor implementation progress, security control coverage, incident readiness and recovery performance. Overall, the project provides a structured and prioritised approach for improving ransomware resilience, protecting sensitive healthcare information and supporting the continuity of essential healthcare services.

TABLE OF CONTENTS

Preliminary Pages

CHAPTER ONE: INTRODUCTION AND PROJECT OVERVIEW

1.1 Introduction
1.2 Background of the Organisation
1.3 Problem Statement
1.4 Project Aim
1.5 Project Objectives
1.6 Project Scope
1.7 Project Exclusions and Limitations
1.8 Assessment Framework and Methodology

CHAPTER TWO: CYBERSECURITY CONSULTANCY ENGAGEMENT PACK

2.1 Engagement Overview
2.2 Scope of Work
2.3 Stakeholder Identification and Responsibilities
2.4 Stakeholder Interview Questions
2.5 Project Plan and Timeline

CHAPTER THREE: CYBERSECURITY ASSESSMENT AND CURRENT-STATE ANALYSIS

3.1 Introduction
3.2 Assessment Approach
3.3 Organisational and Technology Environment
  3.3.1 Facility A – Main Facility
  3.3.2 Facility B – Satellite Facility
3.4 Asset Inventory Overview
  3.4.1 Key Asset Subsets
3.5 Asset Criticality and CIA Triad Assessment
  3.5.1 Criticality Classification
3.6 Baseline Controls and Identified Gaps
  3.6.1 Identity and Privileged Access
  3.6.2 Endpoint Vulnerabilities
  3.6.3 Network Architecture
  3.6.4 Security Monitoring
  3.6.5 Backup Infrastructure Exposure
3.7 Current-State Assessment Summary

CHAPTER FOUR: CYBERSECURITY RISK ASSESSMENT

4.1 Introduction
4.2 Methodology and Rating Scales
  4.2.1 Likelihood Scale
  4.2.2 Impact Scale
  4.2.3 Risk Calculation and Scoring Bands
4.3 Canonical Cybersecurity Risk Register (R01–R15)
  4.3.1 Risk Ownership and Accountability
  4.3.2 Risk Treatment Approach
4.4 Incorporation of Additional Threat Scenarios
4.5 Risk Assessment Limitations

CHAPTER FIVE: SECURITY IMPROVEMENT DESIGN AND PRIORITISED SECURITY ARCHITECTURE

5.1 Introduction
5.2 Target Security Architecture and Design Principles
  5.2.1 Defence in Depth
  5.2.2 Zero Trust and Least Privilege
  5.2.3 Network Segmentation
  5.2.4 Centralised Security Visibility
  5.2.5 Resilient Backup and Recovery
  5.2.6 Risk-Based Implementation
5.3 Overall Zone-Based Security Architecture
5.4 Network Segmentation and Permitted Traffic Flows
  5.4.1 NET-1: Seven-Zone Network Segmentation and Default-Deny Policy
  5.4.2 NET-2: Network Access Restrictions and Lateral Movement Control
  5.4.3 NET-3: Secure Remote Access
  5.4.4 NET-4: Backup Network Isolation
  5.4.5 NET-5: Controlled Internet and Egress Access
  5.4.6 NET-6: Inter-Facility Communication Restrictions
5.5 Identity and Access Management Architecture
  5.5.1 IAM-1: Central Directory and Single Sign-On
  5.5.2 IAM-2: Multi-Factor Authentication
  5.5.3 IAM-3: Role-Based Access Control
  5.5.4 IAM-4: Privileged Access Management
  5.5.5 Additional Identity Governance Controls
5.6 Endpoint and Infrastructure Security
  5.6.1 END-1: Managed Endpoint Protection
  5.6.2 END-2: Risk-Based Patch Management
  5.6.3 END-3: Endpoint Hardening
  5.6.4 Additional Endpoint Recovery and Coverage Controls
5.7 Monitoring, Logging and Alerting Architecture
  5.7.1 MON-1: Central Log Aggregation
  5.7.2 MON-2: Priority Security Alerts
  5.7.3 MON-3: Incident Escalation
  5.7.4 MON-5: File System Auditing
5.8 Patch and Vulnerability Management
  5.8.1 PATCH-1: Software Inventory and Lifecycle Management
  5.8.2 PATCH-2: Vulnerability Assessment
  5.8.3 PATCH-3: Unsupported Technology Management
5.9 Third-Party Access Governance
  5.9.1 TPA-1: Vendor Access Register
  5.9.2 TPA-2: Controlled Remote Support
  5.9.3 Additional Third-Party Governance
5.10 Backup Protection and Recovery Resilience
5.11 Control-to-Zone Mapping and Defence-in-Depth Coverage
5.12 Ransomware Attack Path and Control Interception
5.13 NIST Cybersecurity Framework 2.0 Alignment
5.14 Implementation Prioritisation
5.15 Expected Security Outcomes
5.16 Summary

CHAPTER SIX: PRACTICAL CONTROL VALIDATION AND LABORATORY DEMONSTRATIONS

6.1 Introduction
6.2 Laboratory Environment Specifications
6.3 Demonstration One: Identity and Access Control (RBAC)
6.3.1 Objective
6.3.2 Setup and Execution
6.3.3 Validation Results
6.3.4 Evidence References
6.4 Demonstration Two: Security Auditing and Monitoring
6.4.1 Objective
6.4.2 Setup and Execution
6.4.3 Validation Results
6.4.4 Security Relevance
6.5 Demonstration Three: Backup and Restoration Integrity Validation
6.5.1 Objective
6.5.2 Synthetic Data Generation
6.5.3 Backup and Restoration Procedure
6.5.4 Cryptographic Hash Comparison Results
6.5.5 Supporting Evidence
6.6 Laboratory Limitations
6.7 Chapter Summary

CHAPTER SEVEN: INCIDENT RESPONSE AND RECOVERY PLAYBOOK

7.1 Playbook Purpose and Scope
7.2 Incident Severity Classification
7.3 Incident Response Workflow
Stage 1: Identification and Reporting
Stage 2: Triage and Assessment
Stage 3: Escalation and Command
Stage 4: Containment
Stage 5: Evidence Preservation
Stage 6: Stakeholder Communication
Stage 7: Eradication
Stage 8: Validated Restoration
Stage 9: Post-Incident Review
7.4 Ransomware Tabletop Exercise: Operation DryRUN
7.4.1 Exercise Overview
7.4.2 Key Gaps Identified
7.4.3 Corrective Actions
7.4.4 Integration with the Improvement Roadmap
7.5 Chapter Summary

CHAPTER EIGHT: COSTED 90-DAY CYBERSECURITY IMPROVEMENT ROADMAP

8.1 Roadmap Overview
8.2 Implementation Phases
8.2.1 Phase One: Stabilise and Assign (Days 1–30)
8.2.2 Phase Two: Visibility and Verification (Days 31–60)
8.2.3 Phase Three: Prove and Embed (Days 61–90)
8.3 Costing Model and Financial Summary
8.3.1 Phase-Based Implementation Cost Summary
8.3.2 Contingency and Full Economic Cost
8.3.3 Annual Recurring Software Licensing Schedule

8.4 Financial Assumptions and Limitations
8.5 Chapter Summary

CHAPTER NINE: CYBERSECURITY AND RECOVERY READINESS MANAGEMENT DASHBOARD

9.1 Dashboard Governance
9.2 Key Performance Indicators
9.3 KPI Measurement and Interpretation
9.4 Mandatory Data-Quality Qualifications
  9.4.1 Endpoint Remediation Reconciliation
  9.4.2 Preliminary Risk Count Baseline
  9.4.3 KPI Evidence Requirements
9.5 Management Reporting and Escalation
9.6 Chapter Summary

CHAPTER TEN: CONCLUSION AND RECOMMENDATIONS

10.1 Project Synthesis
10.2 Summary of Priority Recommendations
10.3 Final Recommendation
10.4 Final Conclusion

END MATTER

References

APPENDIX A: INDIVIDUAL CONTRIBUTION RECORDS

A.1 Team Workstream Summary
A.2 Collaborative Responsibilities

APPENDIX B: MASTER EVIDENCE REGISTER

B.1 Purpose
B.2 Evidence Register
B.3 Evidence Management Requirements

APPENDIX C: LABORATORY TECHNICAL EVIDENCE

C.1 Purpose
C.2 Laboratory Scripts and Artifacts
  C.2.1 RBAC Test Script
  C.2.2 Process Auditing Setup
  C.2.3 Backup Hash Validation Script
C.3 Evidence Reconciliation

APPENDIX D: CONSOLIDATED CYBERSECURITY RISK REGISTER

D.1 Purpose
D.2 Required Risk Register Fields
D.3 Risk Register Governance

APPENDIX E: SECURITY ARCHITECTURE AND NETWORK-ZONE DESIGN

E.1 Purpose
E.2 Network-Zone Definitions
E.3 Network Security Principles

APPENDIX F: OPERATION DRYRUN TABLETOP EXERCISE

F.1 Exercise Overview
F.2 Exercise Documentation
F.3 Exercise Governance

APPENDIX G: COSTED ROADMAP AND MANAGEMENT DASHBOARD

G.1 Purpose
G.2 Financial Supporting Worksheets
G.3 Management Dashboard
G.4 Financial Reconciliation

APPENDIX H: PROJECT ASSUMPTIONS, LIMITATIONS AND VALIDATION RECORD

H.1 Purpose
H.2 Project Assumptions
H.3 Project Limitations
H.4 Validation Record
H.5 Final Validation Statement

APPENDIX I: PRIORITISED SECURITY ARCHITECTURE DIAGRAM PACKAGE

I.1 Purpose
I.2 Architectural Diagram Register
I.3 Diagram Interpretation and Traceability
I.4 Architecture Status and Limitations

LIST OF ABBREVIATIONS

Abbreviation	Meaning
API	Application Programming Interface
BYOD	Bring Your Own Device
CIA	Confidentiality, Integrity and Availability
CSF	Cybersecurity Framework
DACL	Discretionary Access Control List
EDR	Endpoint Detection and Response
EHR	Electronic Health Record
EMR	Electronic Medical Record
HMO	Health Maintenance Organization
IAM	Identity and Access Management
IP	Internet Protocol
IRT	Incident Response Team
ISP	Internet Service Provider
LIS	Laboratory Information System

MFA	Multi-Factor Authentication
MSP	Managed Service Provider
NAS	Network-Attached Storage
NDPA	Nigeria Data Protection Act
NDPC	Nigeria Data Protection Commission
NIST	National Institute of Standards and Technology
NTFS	New Technology File System
PC	Personal Computer
RBAC	Role-Based Access Control
RDP	Remote Desktop Protocol
RPO	Recovery Point Objective
RTO	Recovery Time Objective
SACL	System Access Control List
SIEM	Security Information and Event Management
SMB	Server Message Block
SQL	Structured Query Language
SSO	Single Sign-On
UPS	Uninterruptible Power Supply
VLAN	Virtual Local Area Network
VPN	Virtual Private Network

CHAPTER ONE
INTRODUCTION AND PROJECT OVERVIEW

1.1 Introduction

Cybersecurity has become an essential requirement for healthcare organisations that depend on digital systems to manage patient information, appointments, billing, internal communication and administrative operations.

The increasing reliance on interconnected technologies exposes healthcare organisations to various cybersecurity threats, particularly ransomware attacks. Such attacks can disrupt essential services, compromise sensitive information, affect business continuity and create significant financial and operational consequences.

This consultancy project, titled *Cybersecurity Risk Assessment and Ransomware Resilience Strategy for a Multi-Site Healthcare Provider*, focuses on assessing a simulated Nigerian private healthcare provider operating across two facilities.

The project adopts the National Institute of Standards and Technology Cybersecurity Framework (NIST CSF) 2.0 as its primary assessment framework, supported by NIST SP 800-30 Rev. 1 for cybersecurity risk assessment.

The engagement examines the organisation's assumed technology environment, identifies potential cybersecurity risks, evaluates existing and desired security outcomes, and develops practical recommendations for improving protection, detection, incident response and recovery.

Selected security controls are also demonstrated in an isolated laboratory environment using synthetic business data. All activities are conducted within approved academic boundaries, without unauthorised testing of real healthcare systems.

1.2 Background of the Organisation

The case organisation is a simulated Nigerian private healthcare provider operating across two facilities:

- **Facility A (FAC-A):** Main healthcare facility.
- **Facility B (FAC-B):** Satellite healthcare facility.

For the purpose of this assessment, the organisation is assumed to have approximately 80 employees distributed across clinical, administrative, finance, management and IT functions.

Its essential business operations depend on several digital systems and technology resources, including:

- Electronic patient record systems.
- Patient registration and appointment scheduling applications.
- Billing and administrative applications.
- Email and internal communication platforms.
- Shared file storage.
- User workstations and representative servers.
- Network infrastructure.
- Third-party technology and cloud services.

The organisation's operational priorities include maintaining access to essential information, protecting sensitive records and restoring critical services following a cybersecurity incident.

The precise technical architecture, number of endpoints, data volumes, software products and existing security controls are defined through the project baseline and its supporting assessment records. Where direct

organisational verification is unavailable, the relevant characteristics are treated as scenario assumptions rather than independently confirmed findings.

1.3 Problem Statement

Healthcare organisations face increasing cybersecurity risks due to their dependence on digital infrastructure and interconnected business applications.

For the simulated healthcare provider, potential weaknesses in user access management, software updates, security monitoring, network separation, third-party access and backup arrangements may increase exposure to ransomware incidents.

A successful ransomware attack could disrupt access to patient records, appointment systems, billing applications and shared business information. Such an incident could affect operations across both facilities, delay clinical and administrative processes, increase recovery expenses and potentially expose sensitive information.

The central problem addressed by this consultancy is the need to establish an evidence-based understanding of the simulated organisation's cybersecurity risks and determine the security improvements required to strengthen its ransomware resilience.

The project addresses this need through a structured cybersecurity assessment, risk prioritisation, security improvement design, controlled laboratory demonstrations and the development of incident response and recovery arrangements.

1.4 Project Aim

To assess the cybersecurity risks and ransomware resilience of a simulated multi-site healthcare provider and develop an evidence-based, prioritised and cost-conscious strategy for protecting critical systems, responding to ransomware incidents and restoring essential services.

1.5 Project Objectives

The project has six specific objectives:

1. **Asset Identification:** Develop a documented inventory of critical systems, information assets, business processes, user groups and external dependencies represented in the approved case baseline.
2. **Cybersecurity Assessment:** Develop NIST CSF 2.0 Current and Target Profiles covering all six framework functions, identifying documented gaps and their supporting evidence.
3. **Risk Prioritisation:** Produce a risk register containing at least 15 distinct ransomware-related or supporting cybersecurity risks, with documented likelihood, impact, risk ratings, proposed owners and recommended treatments.
4. **Security Improvement Design:** Develop a prioritised security architecture covering identity and access management, endpoint security, network segmentation, monitoring, patch management, third-party access and backup protection.
5. **Control Validation and Recovery:** Complete three documented control demonstrations in an approved isolated laboratory, including a backup restoration test using synthetic business data.
6. **Resilience and Implementation Planning:** Produce an incident response playbook, conduct a ransomware tabletop exercise, develop a management dashboard and prepare a costed 90-day improvement roadmap.

1.6 Project Scope

The consultancy assessment covers the simulated healthcare provider's critical information assets, supporting technologies and operational processes.

The scope includes:

- Electronic patient record systems and associated data stores.
- Patient registration and appointment scheduling systems.
- Billing and administrative applications.
- Email, collaboration tools and shared storage.
- User workstations, representative servers and network infrastructure.
- Identity management, authentication and privileged accounts.
- Remote and third-party access arrangements.
- Endpoint protection and software updates.
- Security logging, monitoring and incident escalation.
- Backup arrangements and restoration procedures.
- Staff responsibilities and security awareness.
- Business continuity considerations for essential services.

The assessment considers both healthcare facilities and their assumed technology and business relationships.

1.7 Project Exclusions and Limitations

The following activities are excluded unless formally authorised through an approved change to the project scope:

- Testing or scanning real healthcare systems.
- Accessing real patient records or personal information.
- Deploying live ransomware or destructive malware.
- Conducting unauthorised penetration testing or phishing campaigns.
- Attempting to bypass third-party security controls.
- Modifying production systems or actual backup repositories.
- Certifying legal or regulatory compliance.
- Implementing recommendations in a real healthcare organisation.

The simulated nature of the case means that the project cannot independently establish the security posture of an actual healthcare provider.

Laboratory demonstrations represent selected systems and behaviours only. Any limitations in tools, configurations, resources or testing depth are documented in the relevant technical sections.

1.8 Assessment Framework and Methodology

The project uses NIST CSF 2.0 as its primary cybersecurity assessment framework.

The framework comprises six core functions:

1. Govern (GV).
2. Identify (ID).
3. Protect (PR).
4. Detect (DE).
5. Respond (RS).
6. Recover (RC).

NIST SP 800-30 Rev. 1 provides additional guidance for identifying, analysing and prioritising cybersecurity risks, while NIST SP 800-207 informs the proposed Zero Trust Architecture principles.

The assessment methodology consists of:

1. Asset identification and classification.
2. Baseline information collection and evidence review.
3. Current Profile development.
4. Cybersecurity threat and vulnerability identification.
5. Risk analysis and prioritisation.
6. Target Profile development.
7. Gap analysis and security improvement design.
8. Laboratory control validation.
9. Incident response and recovery planning.
10. Implementation roadmap development and management reporting.

The project distinguishes between confirmed laboratory observations, documented case information, scenario assumptions and findings requiring further validation.

CHAPTER TWO
CYBERSECURITY CONSULTANCY ENGAGEMENT PACK

2.1 Engagement Overview

This chapter establishes the consultancy engagement arrangements for the cybersecurity risk assessment and ransomware resilience project.

The engagement provides a structured approach for examining the simulated healthcare provider's cybersecurity environment, identifying potential weaknesses and developing practical recommendations.

The project is coordinated by the Team Lead and Governance Coordinator, with specific workstreams assigned to technical and assessment leads.

2.2 Scope of Work

The consultancy engagement covers seven primary work areas.

A. Project Governance and Engagement Coordination

- Establish project scope and objectives.
- Coordinate team activities and responsibilities.
- Monitor progress and deliverables.
- Maintain documentation and decision records.
- Ensure activities remain within approved academic boundaries.

B. Cybersecurity Assessment

- Identify critical information assets.
- Examine business processes and dependencies.
- Develop NIST CSF 2.0 Current and Target Profiles.
- Identify and document cybersecurity gaps.
- Maintain supporting assessment evidence.

C. Risk Assessment

- Identify ransomware-related cybersecurity risks (`R01–R15`).
- Define likelihood and impact criteria.
- Calculate risk ratings.
- Assign risk owners and recommend treatment measures.
- Estimate residual risks.

D. Security Improvement Design

- Develop identity and access management recommendations.
- Recommend endpoint protection improvements.
- Design network segmentation arrangements.
- Recommend security monitoring capabilities.
- Improve backup and recovery arrangements.
- Address third-party access risks.

E. Technical Validation

- Establish an isolated laboratory environment.
- Demonstrate selected security controls.
- Test access control and monitoring arrangements.
- Perform synthetic business data backup restoration.
- Document results, evidence and limitations.

F. Incident Response and Recovery Planning

- Develop ransomware incident response procedures.
- Establish escalation and containment arrangements.
- Define recovery priorities.
- Conduct a ransomware tabletop exercise (Operation DryRUN).
- Document stakeholder communication procedures.

G. Implementation Planning and Reporting

- Develop a costed 90-day improvement roadmap.
- Prepare a management dashboard.
- Consolidate assessment findings into the final consultancy report.

2.3 Stakeholder Identification and Responsibilities

The project identifies key stakeholder roles and assigns specific responsibilities to the project team.

Table 2.1: Workstream Allocation and Responsibilities

Stakeholder / Role	Assigned Team Member	Primary Responsibility
Project Supervisor	Academic Facilitator	Review scope, provide guidance and approve academic progression
Team Lead and Governance Coordinator	Alphonsus Stephen Chibuike	Overall engagement coordination, scope management and final consolidation
Assessment and NIST CSF Lead	Laban Emmanuel Rakum	Asset inventory, NIST CSF profiling and baseline gap analysis
Risk Assessment Lead	Nicholas Atacha	Risk register (`R01–R15`), scoring and prioritisation
Security Architecture Lead	Oreofe Dada	Target security design across seven technical domains
Technical Validation Lead	Owiliwa Clever Goodluck	Laboratory setup, RBAC, audit testing and backup recovery
Incident Response and Roadmap Lead	Oyewale Akinrinde	Playbook, tabletop exercise, roadmap costing and dashboard
Simulated Management and IT	Scenario personas	Provide assumed operational parameters and system requirements

2.4 Stakeholder Interview Questions

The following structured interview questions were developed to support stakeholder engagement and scenario elicitation.

A. Management and Governance

1. What are the organisation's most critical business and healthcare services?

2. Which services must be restored first following a major cybersecurity incident?
3. Who is responsible for approving cybersecurity policies and risk treatment decisions?
4. How does management currently monitor cybersecurity risks?
5. What level of service interruption would be considered unacceptable?

B. IT and Technical Operations

1. What major systems and devices support daily operations across FAC-A and FAC-B?
2. How are user accounts and administrative privileges managed?
3. Are multi-factor authentication (MFA) and least-privilege access enforced?
4. How are operating system and software updates managed?
5. What security tools exist for endpoint monitoring and log collection?
6. How are suspicious network activities identified and escalated?

C. Clinical and Administrative Departments

1. Which digital systems are essential for daily clinical operations?
2. What operational procedures exist when EHR or appointment systems become unavailable?
3. Are alternative paper-based downtime procedures maintained and tested?
4. How would clinical staff report suspected ransomware activity?

D. Finance and Administration

1. Which applications support billing, payment processing and HMO claims?
2. What would be the financial consequences of losing access to billing records?
3. Who is authorised to access and modify financial information?

E. Third-Party Service Providers

1. Which external vendors or MSPs have remote access to internal systems?
2. How is third-party access authenticated, authorised and monitored?
3. Are remote connections protected by MFA and session logging?
4. What procedures exist for disabling expired vendor access?

F. Backup and Recovery Responsibilities

1. How frequently are critical business data and system configurations backed up?
2. Where are backup repositories located, and are they protected from domain administrator compromise?
3. Are immutable or offline backup copies maintained?
4. When was the last full system restoration test conducted?

Engagement Status Note: These questions represent structured discussion templates for scenario elicitation. They must not be interpreted as completed stakeholder interviews. Any responses used to establish the baseline must be identified as documented responses, simulated responses or assumptions.

2.5 Project Plan and Timeline

The engagement follows an eight-week schedule running from 27 October 2026 to 22 December 2026.

Table 2.2: Engagement Schedule

Period	Planned Activities	Lead Responsibility
Week 1: 27 October–2 November	Project charter confirmation, roles, scope definition and case baseline setup	Alphonsus and all members
Week 2: 3–9 November	Asset inventory refinement, interview question design and evidence indexing	Laban and Alphonsus
Week 3: 10–16 November	NIST CSF Current Profile development, gap analysis and initial risk drafting	Laban and Nicholas
Week 4: 17–23 November	Risk prioritisation, Target Profile establishment and security architecture design	Nicholas and Oreofe
Week 5: 24–30 November	Laboratory setup, RBAC testing and process audit validation	Owiliwa and Oreofe
Week 6: 1–7 December	Backup restoration laboratory execution and incident playbook drafting	Owiliwa and Oyewale
Week 7: 8–14 December	Operation DryRUN tabletop exercise, dashboard setup and roadmap costing	Oyewale and all members
Week 8: 15–22 December	Evidence reconciliation, final report consolidation and submission review	Alphonsus and all members

The schedule provides the planned engagement sequence.

CHAPTER THREE
CYBERSECURITY ASSESSMENT AND CURRENT-STATE ANALYSIS

3.1 Introduction

This chapter presents the cybersecurity assessment of the simulated healthcare provider. It examines the organisation's assumed technology infrastructure, user groups, asset landscape, baseline security controls and current-state security posture against NIST CSF 2.0.

The assessment utilises the 50-record master asset inventory developed across nine functional categories supporting operations at Facility A (FAC-A Main Facility) and Facility B (FAC-B Satellite Facility).

The chapter establishes the technical baseline from which the subsequent risk assessment and security improvement recommendations are developed.

3.2 Assessment Approach

The current-state analysis follows a structured assessment workflow:

1. Classification of information and physical technology assets across both facilities.
2. CIA Triad scoring to determine asset criticality.
3. Review of baseline control configurations as described in the scenario assessment records.
4. NIST CSF 2.0 Current Profile mapping across Govern, Identify, Protect, Detect, Respond and Recover.
5. Identification of supporting evidence gaps and technical exposure areas.

The assessment distinguishes between documented scenario baseline findings and technical observations directly validated in the laboratory.

3.3 Organisational and Technology Environment

The healthcare provider operates across two physical locations.

3.3.1 Facility A – Main Facility

FAC-A is assumed to host the primary server room and central technology infrastructure.

The representative server environment includes:

Asset ID	System Description
SV-01	Hyper-V Virtualisation Host
SV-02	EHR Application Server
SV-03	EHR SQL Database Server
SV-04	Active Directory Domain Controller
SV-05	File and Print Server
SV-06	Veeam Backup Server

3.3.2 Facility B – Satellite Facility

FAC-B relies on central infrastructure at FAC-A through a site-to-site IPsec VPN tunnel for access to EHR and billing services.

It also maintains a local Network-Attached Storage device (ST-01) for scanned patient records.

The assumed operating environment includes approximately 80 employees distributed across clinical, administrative, finance, management and IT functions.

Digital operations include patient registration, clinical record management, billing and HMO processing, laboratory analytics, email communications and administrative operations.

3.4 Asset Inventory Overview

The baseline master inventory categorises 50 asset records across nine structural domains.

Table 3.1: 50-Asset Inventory Grouping Summary

Category ID	Asset Category	Asset Count	Asset Identifiers
IA	Information and Data	9	IA-01 to IA-09
AP	Applications	6	AP-01 to AP-06
SV	Servers and Compute	6	SV-01 to SV-06
ST	Storage and Backup	3	ST-01 to ST-03
EP	Endpoints	9	EP-01 to EP-09
NW	Network Infrastructure	7	NW-01 to NW-07
ID	Identity and Access	4	ID-01 to ID-04
SC	Security Tooling	3	SC-01 to SC-03
SI	Supporting Infrastructure	3	SI-01 to SI-03
Total		**50**	

3.4.1 Key Asset Subsets

A. Information and Data (IA-01–IA-09)

The information asset category includes:

- IA-01: Patient EHR data.
- IA-02: Patient registration records.
- IA-04: Billing and HMO claims.
- IA-07: System credentials.
- IA-08: Backup data sets.
- IA-09: System logs.

B. Applications (AP-01–AP-06)

The application category includes:

- AP-01: Electronic Health Record platform.
- AP-02: Patient Registration application.
- AP-03: Billing application.
- AP-04: Microsoft 365.
- AP-05: Accounting application.
- AP-06: Laboratory Information System.

C. Servers and Compute (SV-01–SV-06)

- SV-01: Hyper-V Host.
- SV-02: EHR Application Server.
- SV-03: EHR SQL Database Server.
- SV-04: Active Directory Domain Controller.
- SV-05: File and Print Server.
- SV-06: Veeam Backup Server.

D. Storage and Backup (ST-01–ST-03)

- ST-01: FAC-B Local NAS.
- ST-02: On-site Backup NAS.
- ST-03: Weekly Offsite USB Drive.

E. Endpoints (EP-01–EP-09)

The endpoint category represents nine logical endpoint asset records covering clinical workstations, registration terminals, cashier systems, finance workstations, IT administration devices, laptops, mobile devices and laboratory analyser PCs.

The wider scenario baseline identifies 66 physical PC units. These are represented through the endpoint category records and should be reconciled against the detailed endpoint register before reporting device-level remediation.

F. Other Asset Categories

The remaining asset categories cover network infrastructure (NW), identity and access resources (ID), security tooling (SC) and supporting infrastructure (SI).

The detailed master inventory workbook remains the authoritative source for individual asset descriptions, ownership, location, criticality and supporting dependencies.

3.5 Asset Criticality and CIA Triad Assessment

Asset criticality is evaluated using the Confidentiality, Integrity and Availability (CIA) Triad.

Each dimension is assigned a qualitative score from 1 to 3:

- **1 – Low:** Limited consequence if the security property is compromised.
- **2 – Moderate:** Noticeable operational or business consequence.
- **3 – High:** Serious consequence for patient care, information protection or business continuity.

The total CIA score is calculated as:

CIA Score = C + I + A

The resulting score ranges from 3 to 9.

3.5.1 Criticality Classification

- **Critical Tier (Score 9):** Assets whose compromise could severely affect patient care, business continuity or the protection of sensitive information. Examples include IA-01, IA-08, AP-01, SV-01, SV-03, SV-04, ST-02 and ST-03.

- **High Tier (Scores 7–8):** Core operational assets such as AP-02, AP-03, SV-05, NW-03 and ID-02.
- **Medium Tier (Scores 5–6):** Supporting tools and infrastructure with more limited operational impact, including EP-08 and SI-03.

Table 3.2: Critical Asset CIA Triad Scoring Summary

The individual C, I and A values for each asset should be reproduced from the approved master asset inventory workbook. The examples above establish the criticality classifications but do not replace the detailed asset-level scoring matrix.

3.6 Baseline Controls and Identified Gaps

The scenario baseline identifies the following major security exposure areas.

3.6.1 Identity and Privileged Access

The assumed baseline includes the use of everyday user accounts for administrative activities, a single domain controller (SV-04), absence of MFA for internal staff and unresolved Security Identifiers (SIDs) in local administrator groups.

These conditions could increase the likelihood of privilege escalation, unauthorised access and widespread infrastructure compromise.

3.6.2 Endpoint Vulnerabilities

The baseline identifies 21 of 66 PCs as running Windows 10 without Extended Security Updates after the operating system's standard support termination.

The endpoint environment is assumed to rely primarily on standalone Microsoft Defender Antivirus without centralised management or full EDR capabilities.

This creates potential exposure to unpatched vulnerabilities, inconsistent security configurations and delayed detection of malicious activity.

3.6.3 Network Architecture

The assumed network architecture includes:

- Flat internal network arrangements at both facilities.
- Guest Wi-Fi connected to an internal LAN segment.
- Direct inbound internet RDP port-forwarding to SV-02 for vendor support.

These conditions increase the potential for unauthorised network access and lateral movement following endpoint or credential compromise.

3.6.4 Security Monitoring

The baseline identifies the absence of a central security log repository and centralised SIEM capability.

System logs are assumed to remain distributed across local endpoints and servers, limiting central visibility and making coordinated threat investigation more difficult.

SC-02 represents the central monitoring capability proposed for implementation rather than an existing production deployment.

3.6.5 Backup Infrastructure Exposure

The baseline identifies several backup-related weaknesses:

- Veeam backup server (SV-06) operates as a virtual machine on the Hyper-V host (SV-01) that it protects.
- Primary backup NAS (ST-02) is domain-joined and writable using domain administrator credentials.
- FAC-B NAS (ST-01) is excluded from automated Veeam backup jobs.
- Weekly offsite USB rotation (ST-03) lacks automated integrity verification.

These conditions may increase the possibility that a successful domain compromise could affect both primary infrastructure and backup resources.

3.7 Current-State Assessment Summary

The current-state assessment identifies five major areas requiring priority improvement:

1. Identity and privileged access management.
2. Endpoint security and vulnerability management.
3. Network segmentation and remote access protection.
4. Centralised security monitoring and incident detection.
5. Backup isolation and recovery assurance.

These findings provide the basis for the 15-risk register presented in Chapter Four and the proposed target security architecture in Chapter Five.

Assessment qualification: The findings in this chapter describe the approved simulated case baseline. They should be supported by the corresponding scenario records and asset inventory, not presented as independently verified findings from an actual healthcare organisation.

CHAPTER FOUR
CYBERSECURITY RISK ASSESSMENT

4.1 Introduction

This chapter presents the cybersecurity risk assessment conducted for the simulated multi-site healthcare provider. It identifies potential threat scenarios, vulnerabilities, affected assets, operational consequences and recommended treatment measures.

The assessment adopts the canonical risk register comprising 15 distinct risks (`R01–R15`). These identifiers serve as the standard references across the technical, operational and management deliverables.

4.2 Methodology and Rating Scales

The risk assessment follows the principles of NIST SP 800-30 Rev. 1, using five-point qualitative scales to evaluate likelihood and impact.

4.2.1 Likelihood Scale

Table 4.1: Qualitative Likelihood Scale

Score	Classification	Description
1	Rare	Highly unlikely to occur under normal operating conditions
2	Unlikely	Not expected to occur frequently
3	Possible	May occur under identifiable circumstances
4	Likely	Strong possibility of occurrence
5	Almost Certain	Expected to occur frequently or continually

4.2.2 Impact Scale

Table 4.2: Qualitative Impact Scale

Score	Classification	Description
1	Negligible	Minimal operational effect
2	Minor	Limited disruption and minor financial consequences
3	Moderate	Noticeable disruption to clinical or administrative processes
4	Major	Severe disruption to healthcare operations or sensitive data exposure
5	Severe	Extensive compromise, major financial loss, complete service disruption or potential patient safety consequences

4.2.3 Risk Calculation and Scoring Bands

Risk scores are calculated by multiplying the assigned likelihood and impact values.

Risk Score = Likelihood × Impact

The resulting scores are classified as follows:

Risk Score	Rating	Required Treatment

1–4	Low	Routine monitoring
5–9	Moderate	Planned remediation
10–16	High	Priority treatment required
17–25	Critical	Immediate management attention and treatment

The likelihood and impact scores must be documented individually for each risk. The qualitative ratings in the summary register below are preliminary classifications pending completion or reconciliation of the detailed numerical scoring matrix.

4.3 Canonical Cybersecurity Risk Register (R01—R15)

The following 15 risks form the master reference register for the project.

Table 4.3: Canonical Risk Register Summary

Risk ID	Risk Title and Threat Scenario	Primary Impact Area	Preliminary Rating	Proposed Risk Owner
R01	**Phishing and Credential Theft:** Deceptive emails harvest staff credentials to gain access to email and internal EHR platforms.	Identity and Data Disclosure	High	IT/Security Lead
R02	**Excessive User Privileges:** Standard staff retain folder or system permissions beyond job requirements.	Data Confidentiality	High	IT Lead and Data Owners
R03	**Administrator Account Misuse or Compromise:** Compromise of domain administrative accounts grants extensive network control.	Infrastructure Control	Critical	Head of IT
R04	**Delayed Security Updates:** Unpatched operating systems and applications remain exposed to known vulnerabilities.	Endpoint Vulnerability	High	Systems Administrator
R05	**Inadequate Endpoint Protection:** Ransomware executes on workstations lacking centralised EDR prevention and detection.	System Availability	High	IT/Security Lead
R06	**Insufficient Network Segmentation:** Flat network connectivity permits lateral ransomware movement across facilities and servers.	Network Isolation	Critical	Network/Security Lead
R07	**Inadequate Security Monitoring:** Absence of central SIEM monitoring delays detection of malicious activity and lateral movement.	Threat Visibility	High	Security Operations Lead
R08	**Backups Accessible from Compromised Systems:** Domain-joined backup NAS (ST-02) is encrypted or deleted using compromised domain credentials.	Disaster Recovery	Critical	Backup Administrator
R09	**Restoration Not Adequately Tested:** Untested restoration procedures prevent timely recovery of critical systems.	Business Continuity	High	Business Continuity Lead
R10	**Uncontrolled Remote Access:** Direct inbound internet RDP connectivity to SV-02 is exploited to introduce malware.	Remote Access Security	Critical	IT/Security Lead

R11	**Unmanaged Third-Party Accounts:** Shared vendor credentials, including TeamViewer access, are used without sufficient MFA or session monitoring.	Supplier Governance	High	IT Lead and Procurement
R12	**Weak Incident Reporting and Escalation:** Unclear reporting structures delay technical containment during an active attack.	Incident Response	High	Incident Commander
R13	**Inadequate Recovery Priorities:** Absence of agreed RTO and RPO targets results in inappropriate restoration sequencing.	Clinical Operations	High	Clinical Lead and Head of IT
R14	**Accidental Disclosure or Loss of Records:** Human error or improper access configurations expose sensitive information.	Data Privacy	High	Privacy Lead
R15	**Insufficient Staff Ransomware Awareness:** Staff fail to recognise ransomware indicators or follow appropriate device isolation procedures.	Human Risk Factor	Moderate	HR Manager and IT Lead

4.3.1 Risk Ownership and Accountability

Each risk owner is responsible for coordinating the treatment of the assigned risk, monitoring implementation progress and reporting unresolved exposure to management.

Risk ownership does not necessarily mean that the named role performs all technical remediation. Implementation activities may be delegated to the relevant systems administrators, service providers or departmental representatives.

4.3.2 Risk Treatment Approach

The project applies four general risk treatment options:

1. **Mitigate:** Implement technical or administrative controls to reduce likelihood or impact.
2. **Avoid:** Discontinue an activity or exposure that creates unacceptable risk.
3. **Transfer:** Allocate specified financial or contractual consequences to an external party where appropriate.
4. **Accept:** Retain the risk following documented assessment and authorised management approval.

The preferred approach for the critical risks is mitigation, supported by management oversight and documented residual-risk acceptance where necessary.

4.4 Incorporation of Additional Threat Scenarios

Six specialised threat scenarios identified during risk scoping have been incorporated into the canonical risk register to prevent unnecessary duplication.

Additional Threat Scenario	Incorporated Risk References
EHR Ransomware Encryption	R01, R05, R06 and R10
Backup Repository Compromise	R08 and R09
Staff Phishing Campaign	R01 and R15
Medical Device/mIoT Compromise	R06
Vendor Remote Access Exploit	R10 and R11
Domain Controller Takeover	R02 and R03

This consolidation ensures that the project maintains a single set of 15 canonical risks while still addressing the additional threat scenarios.

4.5 Risk Assessment Limitations

The risk ratings in the summary table are preliminary classifications. The complete risk register in Appendix D must contain:

- Affected asset identifiers.
- Threat sources and threat events.
- Vulnerability descriptions.
- Inherent likelihood scores.
- Inherent impact scores.
- Inherent risk calculations.
- Existing controls.
- Recommended treatment measures.
- Residual likelihood and impact scores.
- Residual risk calculations.
- Risk ownership and treatment status.

The project must not report numerical risk reduction or residual-risk effectiveness without a completed and reconciled scoring record.

CHAPTER FIVE
SECURITY IMPROVEMENT DESIGN AND PRIORITISED SECURITY ARCHITECTURE

5.1 Introduction

This chapter presents the proposed target security architecture designed for the simulated multi-site healthcare provider operating across Facility A (FAC-A) and Facility B (FAC-B). The architecture translates the weaknesses and cybersecurity risks identified during the current-state assessment into a prioritised set of security improvements intended to strengthen the organisation's overall security posture and ransomware resilience.

The proposed design adopts a defence-in-depth approach aligned with the National Institute of Standards and Technology (NIST) Cybersecurity Framework (CSF) 2.0 and the principles of Zero Trust Architecture described in NIST Special Publication 800-207. It recognises that healthcare environments depend on the confidentiality, integrity and availability of clinical information systems, patient records, financial applications and supporting infrastructure.

The architecture is organised around seven interconnected security domains:

1. Identity and Access Management.
2. Endpoint Security.
3. Network Segmentation and Secure Access.
4. Monitoring, Logging and Alerting.
5. Patch and Vulnerability Management.
6. Third-Party Access Governance.
7. Backup Protection and Recovery Resilience.

These domains are supported by a ten-diagram architectural package that illustrates the proposed network zones, trust boundaries, permitted communication paths, security controls, monitoring arrangements, backup architecture, third-party access restrictions and implementation priorities.

The proposed architecture is a target-state design. Its inclusion in this report does not imply that every control has already been implemented or independently validated in a live healthcare production environment. Selected control behaviours are examined separately through the practical laboratory activities presented in Chapter Six.

5.2 Target Security Architecture and Design Principles

The proposed architecture is based on the following principles.

5.2.1 Defence in Depth

Security controls are distributed across identity, endpoints, networks, infrastructure, monitoring, third-party access and backup systems. This layered approach is intended to prevent the failure of a single security control from resulting in a complete compromise of the healthcare environment.

5.2.2 Zero Trust and Least Privilege

Access to organisational resources should not be granted solely because a user or device is connected to an internal network. Authentication, authorisation, device context and access permissions should be evaluated before access is granted.

Users and administrators should receive only the permissions required to perform their assigned responsibilities.

5.2.3 Network Segmentation

The environment should be divided into logical security zones with controlled communication between them. Direct access to sensitive infrastructure and backup resources should be restricted to authorised systems and users.

5.2.4 Centralised Security Visibility

Security events from relevant servers, endpoints, network devices and backup infrastructure should be collected and analysed through a central monitoring capability. This improves the ability to identify suspicious activities and coordinate incident response.

5.2.5 Resilient Backup and Recovery

Backup infrastructure should be protected against compromise through administrative separation, restricted access, offline or immutable copies and scheduled restoration testing.

5.2.6 Risk-Based Implementation

Controls should be introduced according to their security importance, operational urgency, implementation dependencies and available resources. Critical exposures, including weak authentication, direct internet-facing remote access and inadequate backup isolation, receive early attention.

5.3 Overall Zone-Based Security Architecture

The proposed network architecture introduces seven logical security zones across FAC-A and FAC-B. Each zone has a defined security purpose, representative systems and access restrictions.

The design is intended to reduce unnecessary communication between systems, restrict lateral movement and protect critical infrastructure from compromise originating from user endpoints or external connections.

Table 5.1: Proposed Seven-Zone Network Segmentation Model

Zone	Security zone	Representative systems
Z1	User Endpoints	FAC-A and FAC-B user workstations
Z2	Clinical Application Servers	SV-02, SV-03
Z3	Shared Data Storage	SV-05, ST-01
Z4	Infrastructure and Domain Management	SV-04
Z5	Isolated Backup Infrastructure	SV-06, ST-02
Z6	Perimeter and Remote Gateways	Firewall and VPN gateway
Z7	Isolated Guest Wi-Fi	Guest wireless devices

The representative systems are assigned to logical zones according to their intended security functions. Final deployment requires confirmation of actual network interfaces, firewall capabilities, routing arrangements and infrastructure dependencies.

The Internet is treated as an external network beyond the seven internal security zones. Similarly, third-party vendors are treated as external entities whose access must pass through approved and monitored access mechanisms.

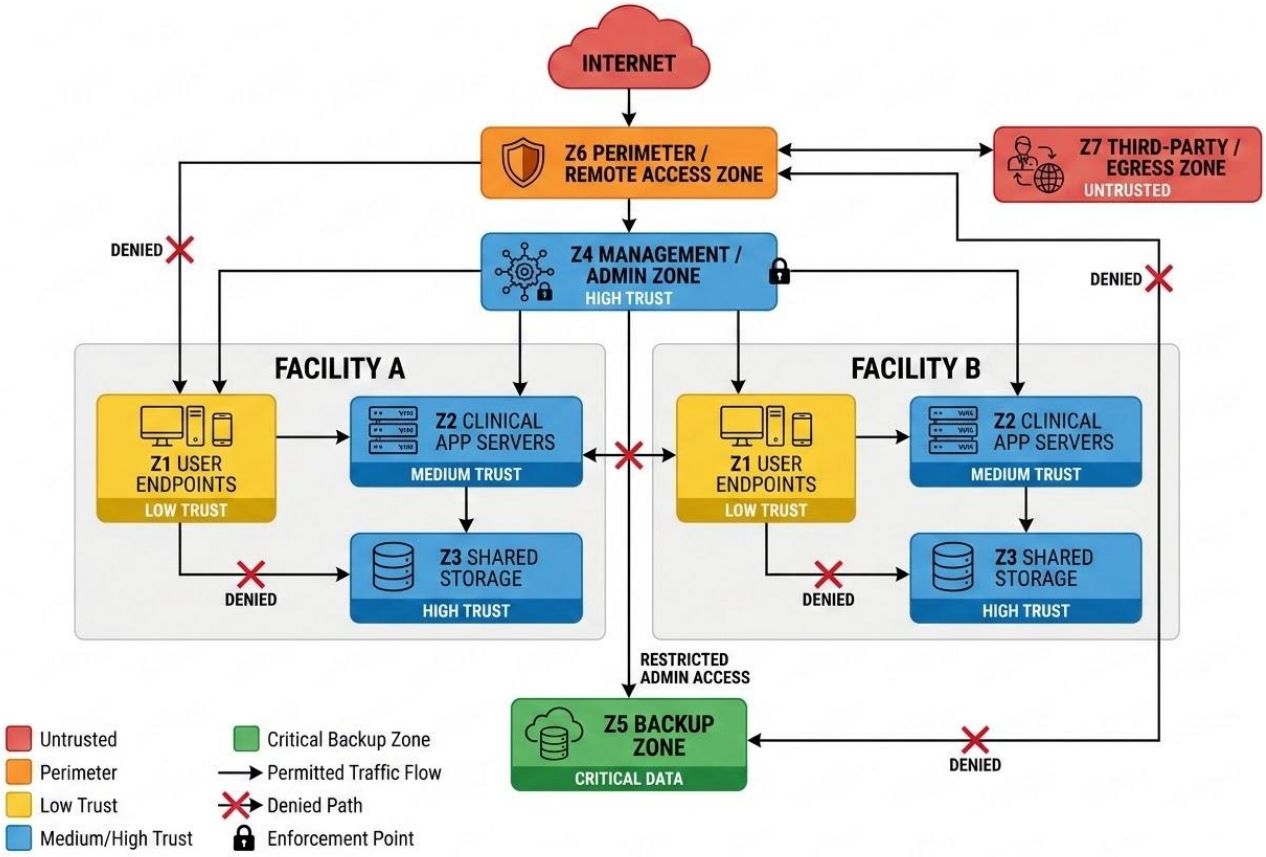


Figure 5.1: Overall Zone-Based Security Architecture for the Simulated Multi-Site Healthcare Provider.

Diagram description: The figure should illustrate all seven security zones, FAC-A and FAC-B, network trust boundaries, the perimeter gateway, permitted communication paths and the locations of the principal security controls. It should also distinguish external Internet connectivity and third-party access from the seven internal zones.

The architecture should enforce default-deny communication between zones, allowing only explicitly authorised business and technical connections. This reduces the possibility of an attacker moving freely between workstations, clinical application servers, administrative infrastructure and backup resources.

The proposed architecture also establishes a restricted inter-facility communication model. Communication between corresponding systems at FAC-A and FAC-B should be permitted only where required for approved clinical or administrative services.

5.4 Network Segmentation and Permitted Traffic Flows

5.4.1 NET-1: Seven-Zone Network Segmentation and Default-Deny Policy

The organisation should implement firewall-supported logical network segmentation across the seven proposed zones.

Inter-zone communication should be denied by default and permitted only when a documented business requirement exists. Firewall rules should specify the source, destination, service, protocol, responsible owner and approval status.

The firewall rule register should provide a formal record of authorised communication paths and support periodic rule reviews.

5.4.2 NET-2: Network Access Restrictions and Lateral Movement Control

Network policies should restrict unnecessary workstation-to-workstation communication and prevent guest wireless devices from accessing internal healthcare applications, storage systems or administrative infrastructure.

Access between user endpoints and clinical application servers should be limited to the required application services. Direct access from user endpoints to backup repositories should be denied.

Administrative communication should originate from authorised management systems or approved administrative access paths.

5.4.3 NET-3: Secure Remote Access

Direct internet-facing RDP port-forwarding to SV-02 should be removed.

Remote access should be provided through an approved VPN or Zero Trust remote access gateway with the following safeguards:

- Multi-factor authentication.
- Individual user accounts.
- Access restrictions based on job responsibilities.
- Approved device requirements where technically feasible.
- Source-IP restrictions where operationally appropriate.
- Session logging and monitoring.
- Periodic access reviews.

This control is classified as P0 because unrestricted remote access may provide an attacker with an entry point into critical healthcare infrastructure.

5.4.4 NET-4: Backup Network Isolation

Backup infrastructure should be separated from routine user and application networks. User endpoints should not be able to initiate direct connections to backup repositories.

Backup access should be restricted to authorised management systems and designated administrative identities.

5.4.5 NET-5: Controlled Internet and Egress Access

Outbound Internet access should be restricted according to operational requirements. Where technically feasible, approved proxy or secure web gateway services should be used to manage outbound connections.

Unnecessary outbound communication from clinical application servers, storage systems and backup infrastructure should be blocked.

5.4.6 NET-6: Inter-Facility Communication Restrictions

Communication between FAC-A and FAC-B should be restricted to approved services, destinations and protocols.

For example, communication between clinical application systems should be allowed only where required to support approved centralised electronic medical record services or other documented operational dependencies.

From ↓ / To →	Z1 Endpoints	Z2 App Servers	Z3 Storage	Z4 Admin	Z5 Backup	Z6 Perimeter	Z7 Internet
Z1 Endpoints	✗ Denied (NET-2)	☑ App ports only	☑ SMB to own shares	✗ Denied	✗ **Denied (NET-4)**	✗ Denied	☑ Via proxy (NET-5)
Z2 App Servers	☑ Response traffic	☑ Required services	☑ Required services	☑ Admin (via Z4)	✗ Denied	✗ Denied	✗ Denied
Z3 Storage	☑ Response traffic	☑ Required services	✗ Denied	☑ Admin (via Z4)	✗ Denied	✗ Denied	✗ Denied
Z4 Admin	☑ Admin (JIT)	☑ Admin (MFA)	☑ Admin (MFA)	☑ Internal	☑ **Backup only (BKP-2)**	☑ Mgmt	☑ Via proxy
Z5 Backup	✗ Denied	✗ Denied	✗ Denied	☑ Response only	☑ Internal	✗ Denied	✗ Denied
Z6 Perimeter	☑ After auth	☑ After auth	☑ After auth	☑ After auth	✗ Denied	☑ Internal	☑ Controlled
Z7 Internet	✗ Denied (inbound)	✗ Denied (inbound)	✗ Denied (inbound)	✗ Denied (inbound)	✗ Denied	☑ Inbound to gateway	☑ Internal

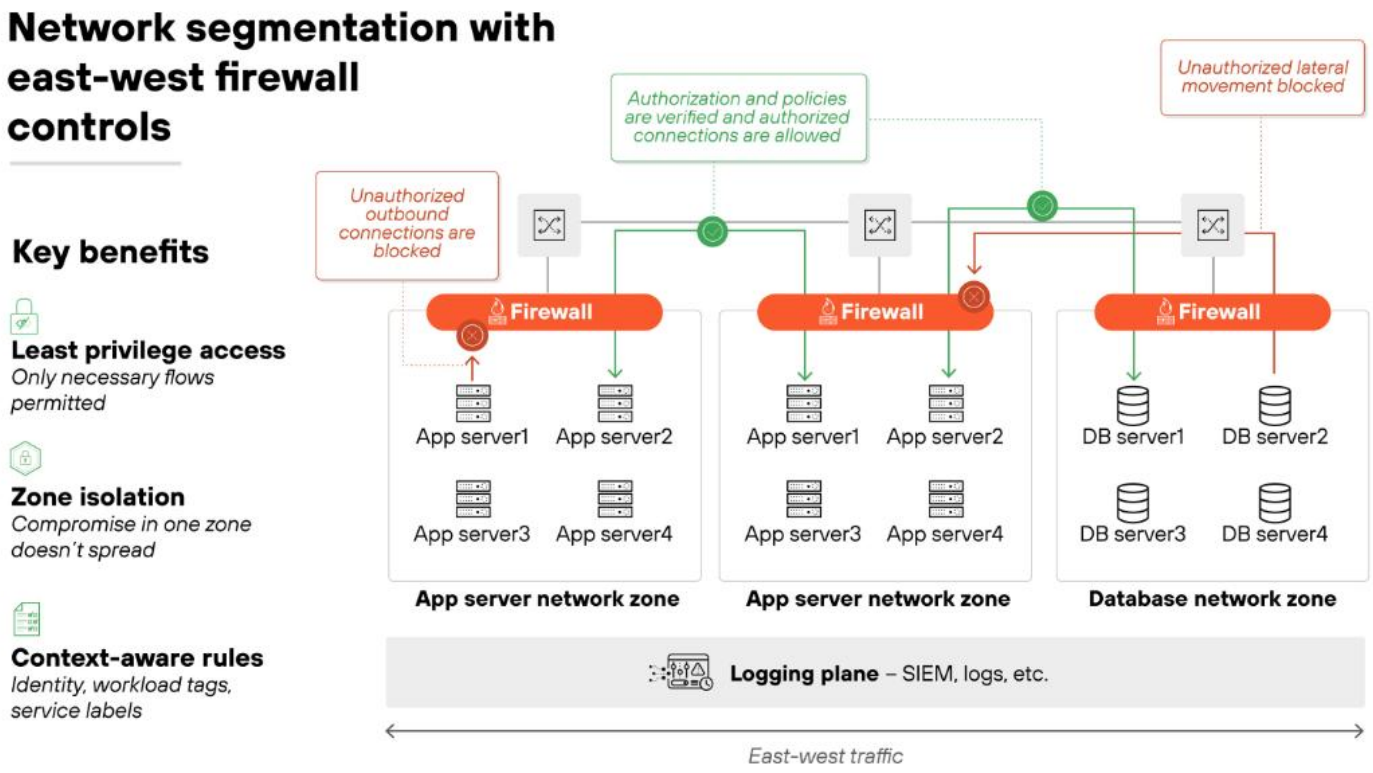


Figure 5.2: Permitted Traffic Flow Matrix and Inter-Zone Communication Restrictions.

Diagram description: The matrix show permitted, restricted and denied communication between Z1–Z7. It should identify the relevant firewall control references, including NET-1 to NET-6, and clearly distinguish internal zones from external Internet and third-party connections.

The traffic matrix should be treated as the basis for the detailed firewall rule register. Authentication alone must not grant unrestricted access to internal networks; network access should remain limited to explicitly authorised services and destinations.

5.5 Identity and Access Management Architecture

The Identity and Access Management domain strengthens user authentication, access authorisation and administrative account protection. It is intended to reduce the risk of credential compromise, privilege abuse and unauthorised access to sensitive healthcare information.

5.5.1 IAM-1: Central Directory and Single Sign-On

User identities should be consolidated through an appropriately configured Active Directory and/or Microsoft Entra ID environment.

Centralised authentication should be supported for electronic health record systems, email and billing applications where technically feasible.

The identity infrastructure should maintain consistent account management, authentication policies and access records across both facilities.

5.5.2 IAM-2: Multi-Factor Authentication

Multi-factor authentication should be enforced for:

- Remote access connections.
- Privileged administrative accounts.
- Microsoft 365 access.
- Financial systems.
- Third-party support connections.

MFA should be implemented using an approved authentication method appropriate to the organisation's technical environment.

This control is classified as P0 because compromised credentials are a common route into organisational systems.

5.5.3 IAM-3: Role-Based Access Control

A documented Role-Based Access Control (RBAC) matrix should be introduced to separate access permissions for Clinical, Billing, Reception and IT personnel.

Permissions should reflect actual job responsibilities and follow the principle of least privilege.

Access to sensitive patient and financial information should be limited to authorised personnel. User permissions should be reviewed when staff change roles, leave the organisation or no longer require access to particular systems.

5.5.4 IAM-4: Privileged Access Management

Administrative access should be separated from routine user activities through dedicated privileged accounts.

The proposed controls include:

- Separate standard and administrative user accounts.
- Use dedicated administrative identities, such as an approved admin_ naming convention.
- Resolve orphaned accounts and unresolved Security Identifiers (SIDs).
- Restrict privileged accounts from routine Internet browsing and general productivity activities.
- Review privileged group membership regularly.
- Apply MFA to privileged access.
- Record and review significant administrative activities.

This control is classified as P0 because excessive or compromised administrative privileges could enable an attacker to compromise multiple systems and security boundaries.

5.5.5 Additional Identity Governance Controls

Identity lifecycle management, periodic access certification and authentication standards should be maintained as supporting IAM activities. Where included in the architectural control register, these should be consistently identified as IAM-5, IAM-6 and IAM-7 respectively, with their detailed requirements documented in the control register.

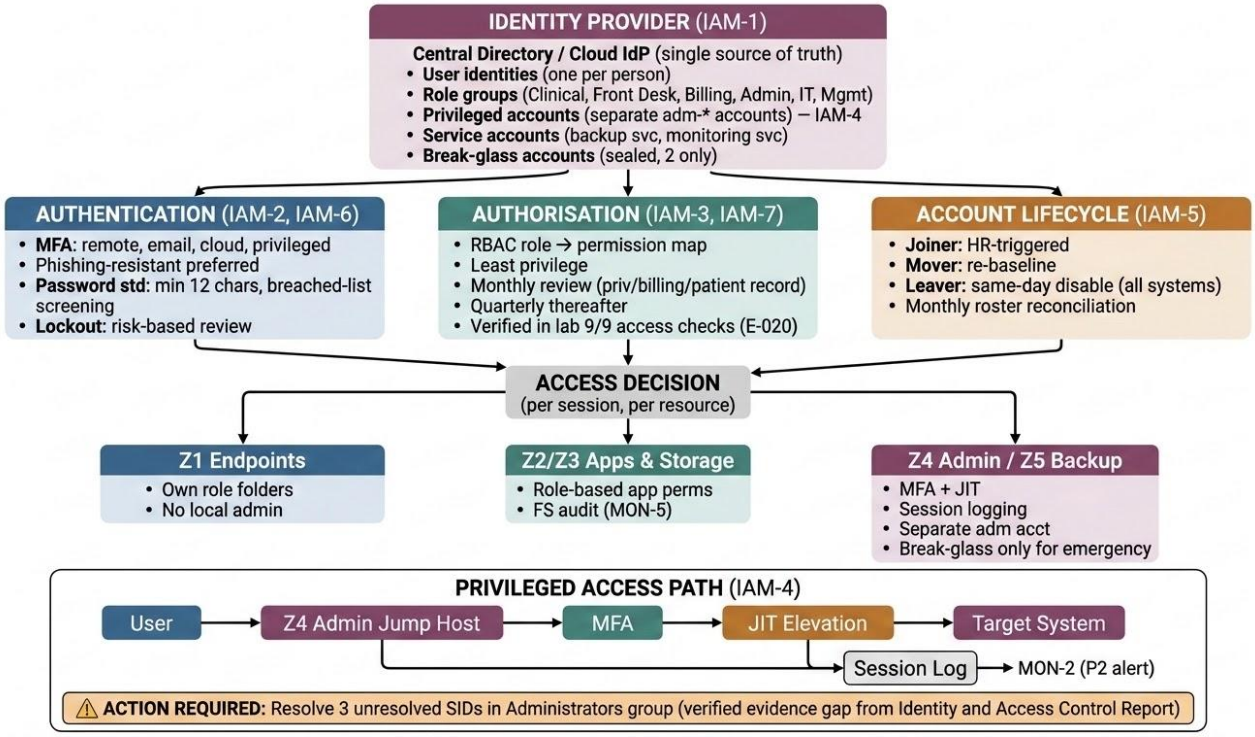


Figure 5.3: Identity and Access Management Flow.

Diagram description: The figure illustrate the relationship between user identities, the central directory, authentication, MFA, RBAC, privileged access management and access to the clinical, financial and administrative applications.

The IAM architecture should demonstrate how users and administrators are authenticated and authorised before accessing organisational resources. It should also show how account lifecycle processes and periodic access reviews support continuing access governance.

5.6 Endpoint and Infrastructure Security

The endpoint security domain is designed to reduce the likelihood of malware execution, unauthorised system modification and exploitation of vulnerable devices.

5.6.1 END-1: Managed Endpoint Protection

Centrally managed endpoint protection should be deployed across the 66 PCs and seven representative servers identified within the simulated environment.

The proposed Microsoft Defender for Business deployment must be checked against applicable server licensing and management requirements. Where necessary, an appropriate server endpoint protection licence should be budgeted separately.

Endpoint protection should support:

- Malware and ransomware detection.

- Suspicious process monitoring.
- Threat isolation and investigation.
- Centralised security alerting.
- Endpoint security status reporting.

This control is classified as P0.

5.6.2 END-2: Risk-Based Patch Management

A documented patch management programme should be established using the following proposed remediation targets:

Vulnerability severity	Target remediation period
Critical	Within 14 days
High	Within 30 days

Exceptions should be documented, risk-assessed and approved by the appropriate technical authority.

Where immediate patching is not possible, compensating controls should be introduced to reduce exposure until remediation can be completed.

5.6.3 END-3: Endpoint Hardening

Endpoint hardening should include:

- Removal of unnecessary local administrative rights.
- BitLocker disk encryption on supported devices.
- Restriction of USB mass storage where operationally appropriate.
- Application control and security configuration baselines.
- Use of supported operating systems and approved software versions.
- Restriction of unnecessary services and applications.

5.6.4 Additional Endpoint Recovery and Coverage Controls

Endpoint recovery and security coverage monitoring should be included in the wider control register where applicable. Proposed references such as END-4 and END-5 must be defined consistently in the control register before being used in the final architecture diagrams.

5.7 Monitoring, Logging and Alerting Architecture

The monitoring domain provides centralised security visibility across the healthcare environment. It is intended to support the early identification of suspicious activity, investigation of security incidents and escalation to the incident response team.

5.7.1 MON-1: Central Log Aggregation

A central Wazuh monitoring and Security Information and Event Management (SIEM) capability should be deployed to collect relevant security logs from:

- Domain Controllers.
- Firewalls.
- Representative servers.

- Supported endpoints.
- Backup infrastructure.

Log collection should be configured according to the technical capabilities of the source systems and the organisation's monitoring requirements.

This control is classified as P0 for establishing initial security visibility.

5.7.2 MON-2: Priority Security Alerts

Monitoring rules should identify significant security events, including the following Windows Security Event IDs:

Event ID	Security event	Monitoring purpose
4688	Process Creation	Identify suspicious process execution and command activity.
4625	Failed Logon	Identify repeated authentication failures and possible credential attacks.
4732	Member Added to Security-Enabled Local Group	Detect changes to local security group membership.

Additional monitoring should cover:

- Suspicious backup service modifications.
- Unusual administrative activity.
- Endpoint security alerts.
- Repeated authentication failures.
- Changes to sensitive files and directories.
- Unexpected changes to privileged group membership.

5.7.3 MON-3: Incident Escalation

A formal alert escalation process should define severity classifications, notification responsibilities and escalation timeframes.

Critical alerts should be escalated to the designated IT and incident response personnel. High-priority events should be investigated and documented according to approved incident handling procedures.

5.7.4 MON-5: File System Auditing

System Access Control Lists (SACLs) should be configured for sensitive patient and financial directories to capture relevant file access activity.

Auditing should support the identification of unauthorised access, suspicious file modifications and unusual access patterns.

Logging configurations must be tested to confirm that relevant events are generated, collected, retained and reviewed.

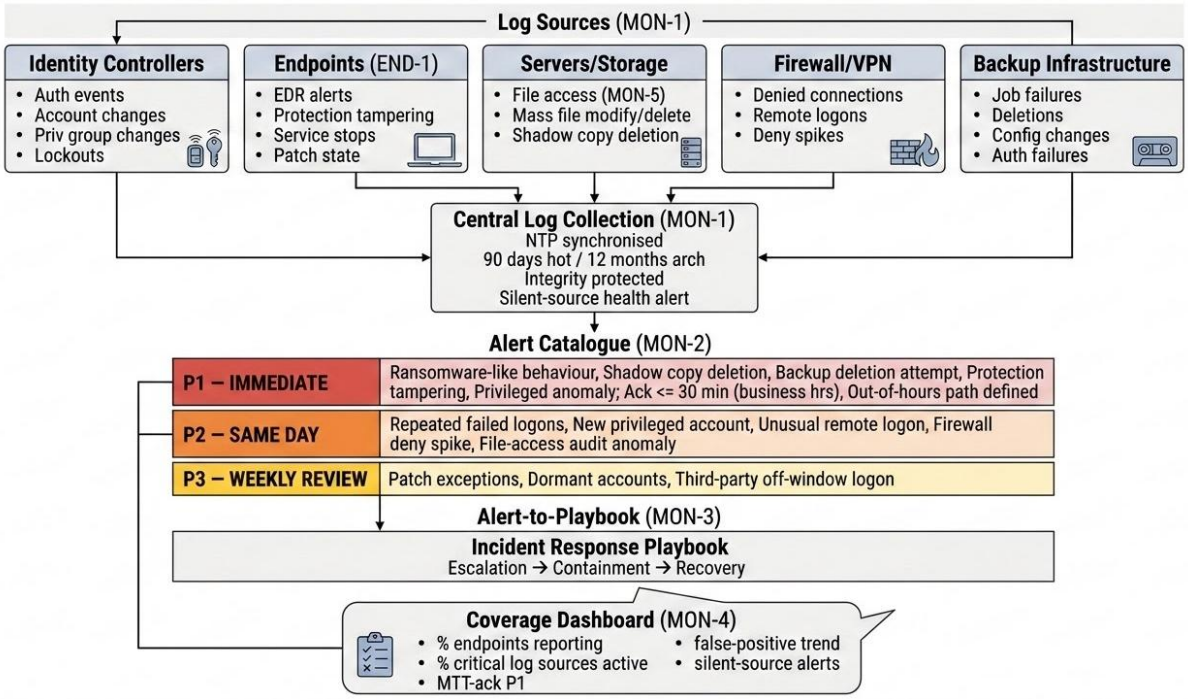


Figure 5.4: Monitoring and Detection Pipeline.

Diagram description: The figure should show how security events from endpoints, domain controllers, firewalls, application servers and backup systems are collected by the central Wazuh monitoring platform. It should then illustrate alert generation, prioritisation, investigation and escalation to the incident response process.

The monitoring design should connect to the incident response arrangements discussed in Chapter Seven. It should also distinguish between events generated locally and alerts successfully received by the central monitoring platform.

5.8 Patch and Vulnerability Management

The patch and vulnerability management domain is intended to reduce the attack surface created by outdated software, unsupported operating systems and unremediated vulnerabilities.

5.8.1 PATCH-1: Software Inventory and Lifecycle Management

An approved software and operating system inventory should be maintained across the organisation.

The inventory should record:

- System and device name.
- Operating system and software version.
- Business owner.
- Support status.
- Patch status.
- Criticality.
- Identified vulnerabilities.

Particular attention should be given to Windows Server 2016 systems. Microsoft lists 12 January 2027 as the end of extended support for Windows Server 2016. Migration planning should therefore be prioritised before this date.

5.8.2 PATCH-2: Vulnerability Assessment

Periodic vulnerability assessments should be conducted using authorised scanning tools and documented remediation procedures.

Findings should be prioritised according to severity, exploitability, business impact and the importance of the affected system.

5.8.3 PATCH-3: Unsupported Technology Management

Unsupported devices and applications should be replaced or upgraded.

Where immediate replacement is not feasible, formally approved compensating controls should be introduced. These may include network isolation, restricted access, enhanced monitoring and additional administrative safeguards.

The organisation should maintain a documented exception register for systems that cannot immediately meet the approved security baseline.

5.9 Third-Party Access Governance

Third-party access presents a potential security exposure where external support personnel require access to internal applications, infrastructure or administrative services.

The proposed architecture establishes controlled, attributable and monitored vendor access.

5.9.1 TPA-1: Vendor Access Register

A central register of third-party accounts and access permissions should be maintained.

Each vendor account should have:

- A named internal owner.
- An approved business purpose.
- A documented access scope.
- An expiration or review date.
- MFA protection where supported.
- Session monitoring and activity records.

Vendor access should be reviewed periodically and revoked when no longer required.

5.9.2 TPA-2: Controlled Remote Support

Shared vendor credentials should be replaced with individually attributable accounts.

Remote support sessions should be initiated through approved access gateways and supervised where appropriate.

Vendor access should be restricted to the specific systems and services required to perform approved support activities.

This control is classified as P0 because uncontrolled third-party access could provide an attacker with an alternative route into internal systems.

5.9.3 Additional Third-Party Governance

Contractual security obligations, access oversight and vendor account revocation should be incorporated into the third-party governance process. Additional references such as TPA-3 and TPA-4 should be defined in the control register if they are retained in the architectural diagrams.

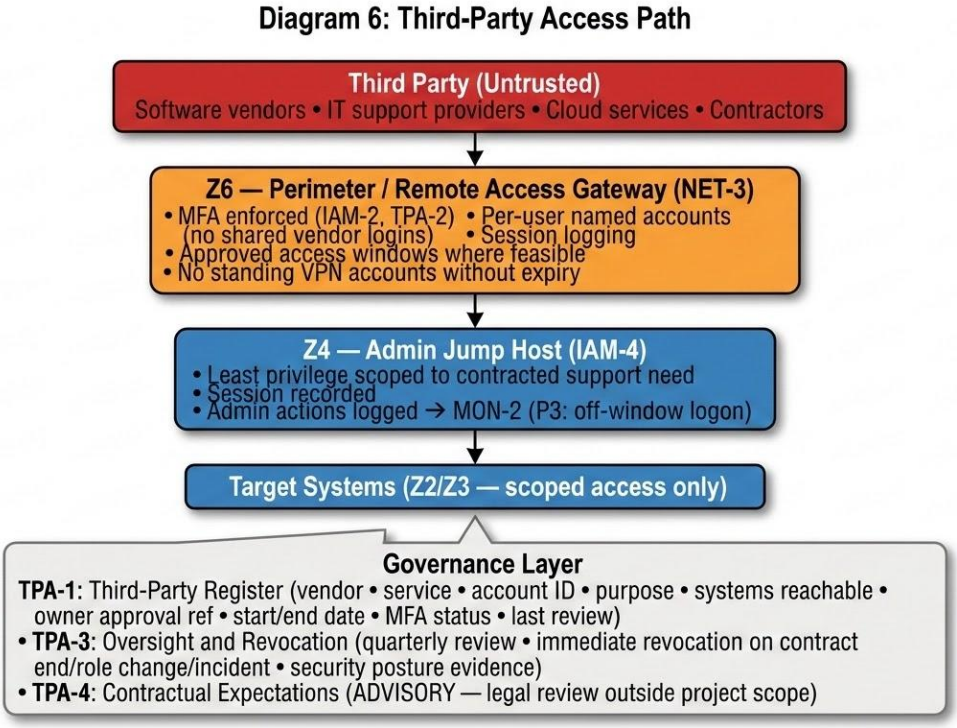


Figure 5.5: Third-Party Access Path.

Diagram description: The figure should show the vendor's external connection, approved remote access gateway, MFA enforcement, internal authorisation, restricted destination systems, session monitoring and access revocation process.

The diagram should make clear that vendors do not receive unrestricted access to the internal network or backup infrastructure.

5.10 Backup Protection and Recovery Resilience

The backup domain is a central part of the proposed ransomware resilience architecture. Its purpose is to protect critical healthcare data and provide a controlled recovery capability following system compromise, accidental deletion or ransomware incidents.

5.10.1 BKP-1: 3-2-1-1 Backup Architecture

The organisation should implement the following backup principles:

- Maintain at least three copies of critical data.
- Use at least two different storage media types.
- Maintain at least one offsite copy.
- Maintain at least one immutable or offline copy.

Backup coverage should include critical clinical applications, shared storage, configuration data and other systems required to restore essential healthcare operations.

5.10.2 BKP-2: Backup Access Hardening

Backup infrastructure should be separated from routine domain administration.

The proposed safeguards include:

- Remove ST-02 from the Active Directory domain where technically feasible.
- Enforce dedicated non-domain administrative credentials.
- Restrict backup administration to authorised personnel.
- Separate backup management from routine domain administration.
- Apply MFA where supported.
- Monitor backup administration and configuration changes.

5.10.3 BKP-3: FAC-B Backup Coverage

The FAC-B NAS identified as ST-01 should be incorporated into approved central backup or equivalent protected backup arrangements.

The organisation should confirm that critical information stored at FAC-B is included in the backup scope and can be restored through an approved process.

5.10.4 BKP-4: Restoration Validation

Scheduled restoration tests should be conducted and documented.

Each test should record:

- Backup source.
- Restoration destination.
- Data integrity verification.
- Restoration duration.
- RPO and RTO performance.
- Responsible personnel.
- Approval and test outcome.

Where appropriate, restored files should be checked using cryptographic hashes to verify data integrity.

5.10.5 Additional Backup Resilience Controls

The backup architecture should also address backup monitoring, recovery priorities and independent recovery capability. Any additional control references, including BKP-5 and BKP-6, should be defined in the control register with clear implementation requirements.

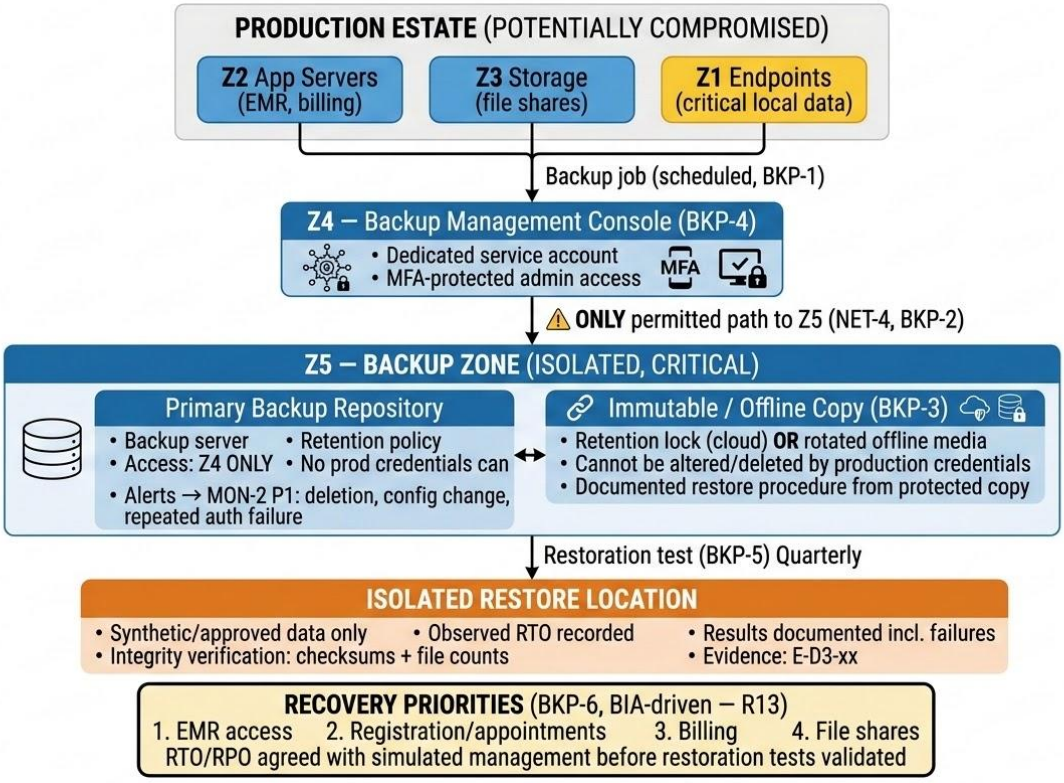


Figure 5.6: Backup and Recovery Architecture.

Diagram description: The figure illustrate the primary backup sources, protected backup path, isolated repository, immutable or offline copy and restoration testing cycle.

An important dependency identified in the project concerns SV-06, the Veeam recovery environment, which currently depends on SV-01 as its hosting infrastructure. If SV-01 becomes unavailable, the recovery environment may also be unavailable until replacement infrastructure is provided and Veeam is rebuilt or restored.

This dependency represents a potential recovery bottleneck and should be addressed through an independent recovery capability, such as a separate physical or cloud-based recovery environment, protected installation media and documented recovery procedures.

The proposed architecture must distinguish between this existing dependency and the recommended future-state improvement. The presence of an independent recovery design in a proposed diagram should not be interpreted as evidence that the dependency has already been removed.

5.11 Control-to-Zone Mapping and Defence-in-Depth Coverage

The security controls described in this chapter are distributed across the seven security zones according to their operational purpose.

The control-to-zone mapping provides a consolidated view of where the principal security controls are enforced and where supporting controls contribute to the overall security posture.

Control	Z1 Endpoints	Z2 App Servers	Z3 Storage	Z4 Admin	Z5 Backup	Z6 Perimeter	Z7 Third Party
IAM-2 MFA	○	○	○	●	●	●	●
IAM-3 RBAC	●	●	●	●	○	○	●
IAM-4 PAM	○	○	○	●	●	○	●
IAM-6 Auth standard	●	●	●	●	●	●	●
END-1 EDR	●	●	○	●	○	○	○
END-2 Patching	●	●	●	●	●	●	○
END-3 Hardening	●	●	●	●	●	●	○
NET-1 Default deny	●	●	●	●	●	●	●
NET-2 Lateral movement	●	●	●	●	○	○	○
NET-3 Remote access	○	○	○	○	○	●	●
NET-4 Backup isolation	○	○	○	●	●	○	○
MON-1 Log collection	●	●	●	●	●	●	○
MON-2 Alert catalogue	●	●	●	●	●	●	●
MON-5 FS auditing	○	○	●	●	○	○	○
PATCH-1/2 Inventory+cadence	●	●	●	●	●	●	○
TPA-1/2 Inventory+restrictions	○	○	○	●	○	●	●
BKP-1 to BKP-5 Backup	○	●	●	●	●	○	○

Figure 5.7: Control-to-Zone Mapping Heat Map.

Diagram description: The heat map should show the relationship between IAM, endpoint, network, monitoring, patch management, third-party and backup controls across Z1–Z7.

The legend should distinguish:

- Primary control location: the zone where the control is principally enforced.
- Supporting or secondary application: a zone where the control provides additional protection.

Third-party access should be represented as an external entity or external access path, not as an eighth internal network zone. Where the original heat map includes a third-party column, it should be clearly labelled as an external access context.

The mapping supports defence-in-depth by showing that the architecture does not depend on a single security technology or control. Instead, identity, endpoint, network, monitoring and recovery controls work together to reduce the likelihood and impact of compromise.

The control references should remain consistent across the architecture diagrams, security control register, risk register and implementation roadmap.

5.12 Ransomware Attack Path and Control Interception

The proposed architecture is designed to reduce the likelihood that an initial compromise will escalate into a widespread ransomware incident.

A typical ransomware attack may involve initial access through compromised credentials, exploitation of exposed services, malicious execution, privilege escalation, lateral movement, data exfiltration, encryption and attempted destruction of backup resources.

The proposed controls are intended to interrupt this sequence at different stages.

Examples include:

- IAM controls to reduce credential compromise and unauthorised access.
- Endpoint protection to identify and contain malicious execution.
- Network segmentation to restrict lateral movement.
- Monitoring controls to identify suspicious activities.
- Third-party access governance to reduce uncontrolled external access.

- Backup isolation and immutable copies to improve recovery options.

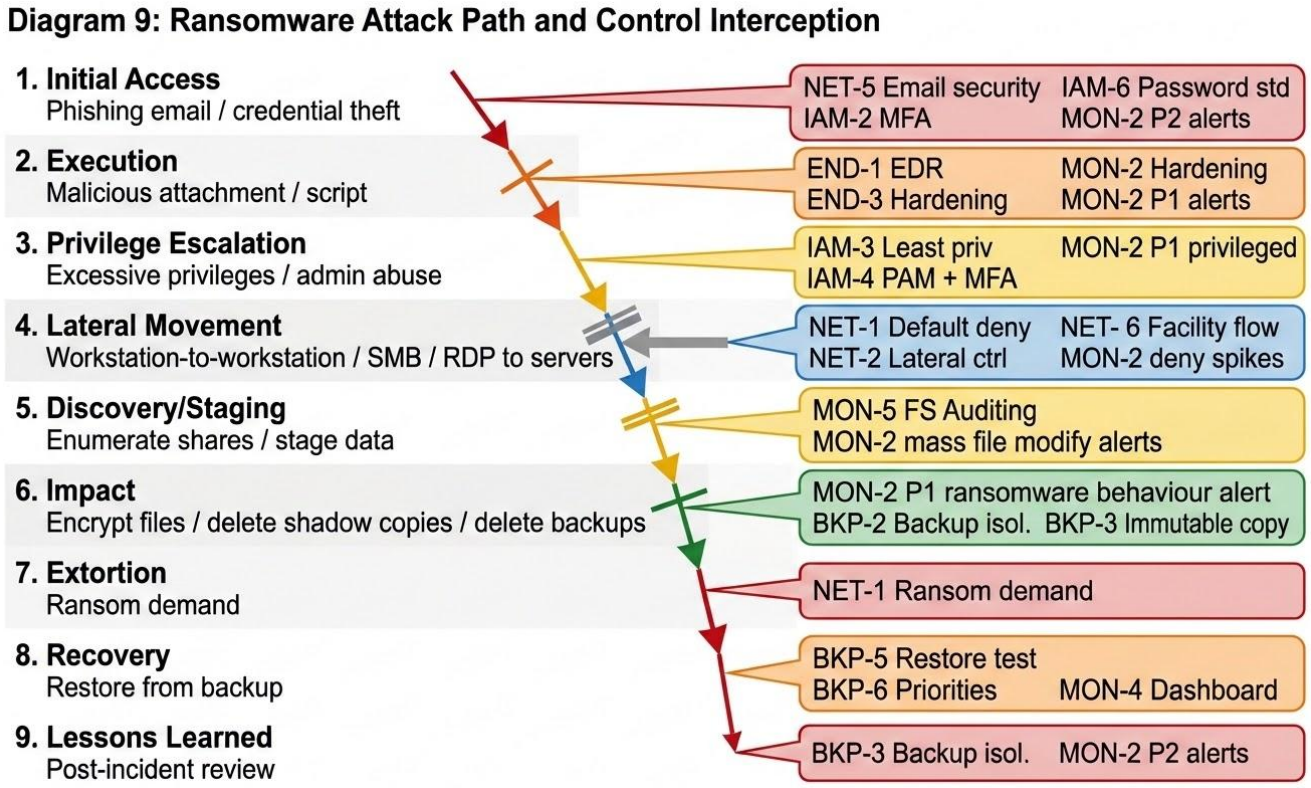


Figure 5.8: Ransomware Attack Path and Control Interception.

Diagram description: The figure should present a typical ransomware attack sequence and identify the proposed controls that may prevent, detect or limit each stage. It should show that segmentation, backup isolation, monitoring and recovery safeguards provide additional protection even where earlier security controls fail.

The architecture follows an assume-breach approach: it recognises that initial access may occur despite preventive controls and therefore prioritises the containment of subsequent activity and protection of recovery resources.

The presence of these controls reduces risk but does not guarantee that ransomware will be prevented or that all systems will remain unaffected.

5.13 NIST Cybersecurity Framework 2.0 Alignment

The proposed architecture is aligned with the six functions of NIST CSF 2.0: Govern, Identify, Protect, Detect, Respond and Recover.

The mapping demonstrates how the proposed controls contribute to the organisation's wider cybersecurity risk management activities.

Table 5.3: Proposed Security Control Alignment with NIST CSF 2.0

CSF 2.0 function	Relevant proposed control areas
Govern	Identity lifecycle governance, third-party oversight, access reviews, policy management and security reporting.

Identify	Asset and software inventory, network rule registers, facility flow mapping and vulnerability identification.
Protect	Central identity, MFA, RBAC, privileged access management, endpoint protection, patching, hardening and network segmentation.
Detect	Central log collection, security alerting, endpoint detection, file system auditing and backup monitoring.
Respond	Incident escalation, incident response playbooks, third-party access revocation and network containment capabilities.
Recover	Backup isolation, immutable copies, restoration testing, recovery prioritisation and endpoint recovery.

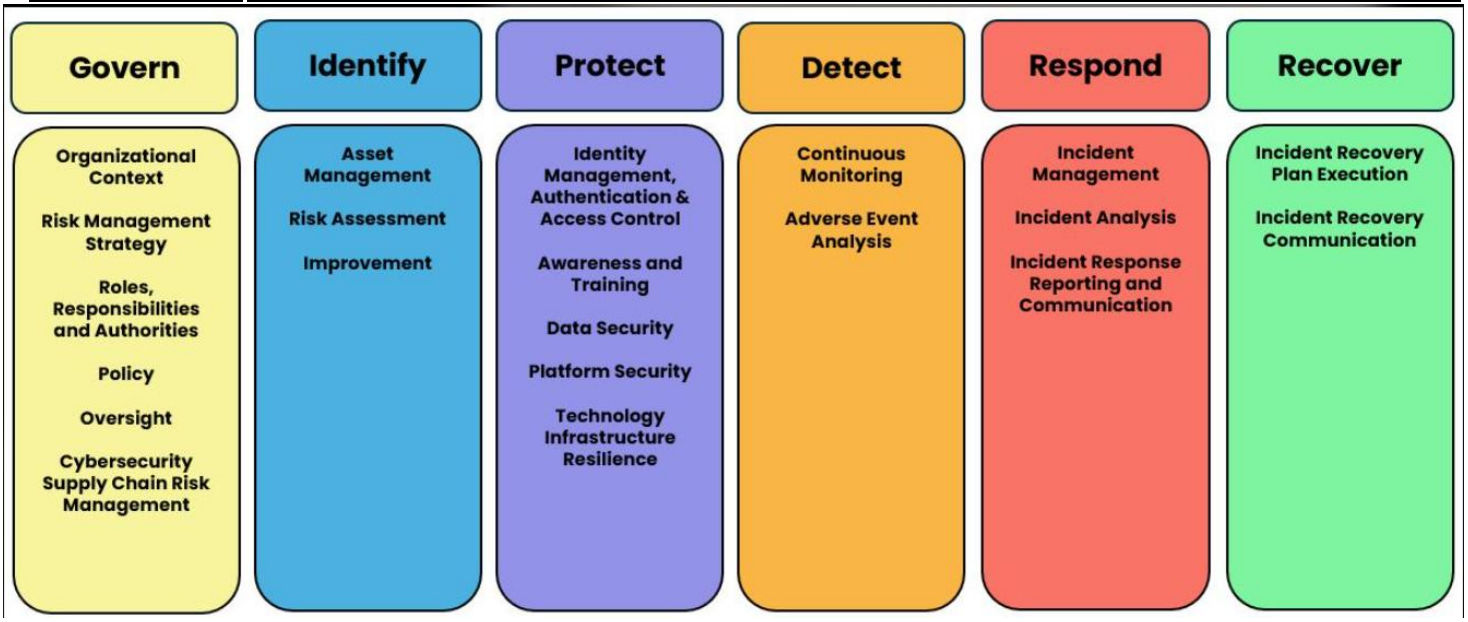


Figure 5.9: NIST Cybersecurity Framework 2.0 Function Coverage Map.

Diagram description: The figure should show how the proposed IAM, endpoint, network, monitoring, patch, third-party and backup controls contribute to the six NIST CSF 2.0 functions.

The mapping supports the integration of security governance, technical protection, monitoring, incident response and recovery into a coordinated security improvement programme.

The CSF alignment should be treated as a mapping of proposed control contributions rather than evidence of formal NIST certification or independently assessed compliance.

5.14 Implementation Prioritisation

The proposed security controls are prioritised according to risk severity, operational urgency, implementation dependencies and their expected contribution to ransomware resilience.

The prioritisation approach is intended to ensure that the most significant exposures are addressed before less urgent enhancements.

Table 5.4: Security Control Implementation Priorities

Priority	Timeframe	Implementation focus

P0 – Critical	Days 1–30	Priority MFA implementation, removal of direct internet-facing RDP, backup isolation, initial endpoint protection and control of uncontrolled vendor access.
P1 – High	Days 31–60	Network segmentation, SIEM deployment, RBAC refinement and third-party access governance.
P2 – Medium	Days 61–90	Egress filtering, password vault rollout, vulnerability management improvements and endpoint operating system modernisation.
P3 – Planned	Beyond 90 days	Automated micro-segmentation, FIDO2 hardware security keys and further security automation.

The priorities should be reviewed against the costed 90-day improvement roadmap. Implementation dependencies, procurement requirements, staff availability and operational constraints should be considered before individual activities are approved.

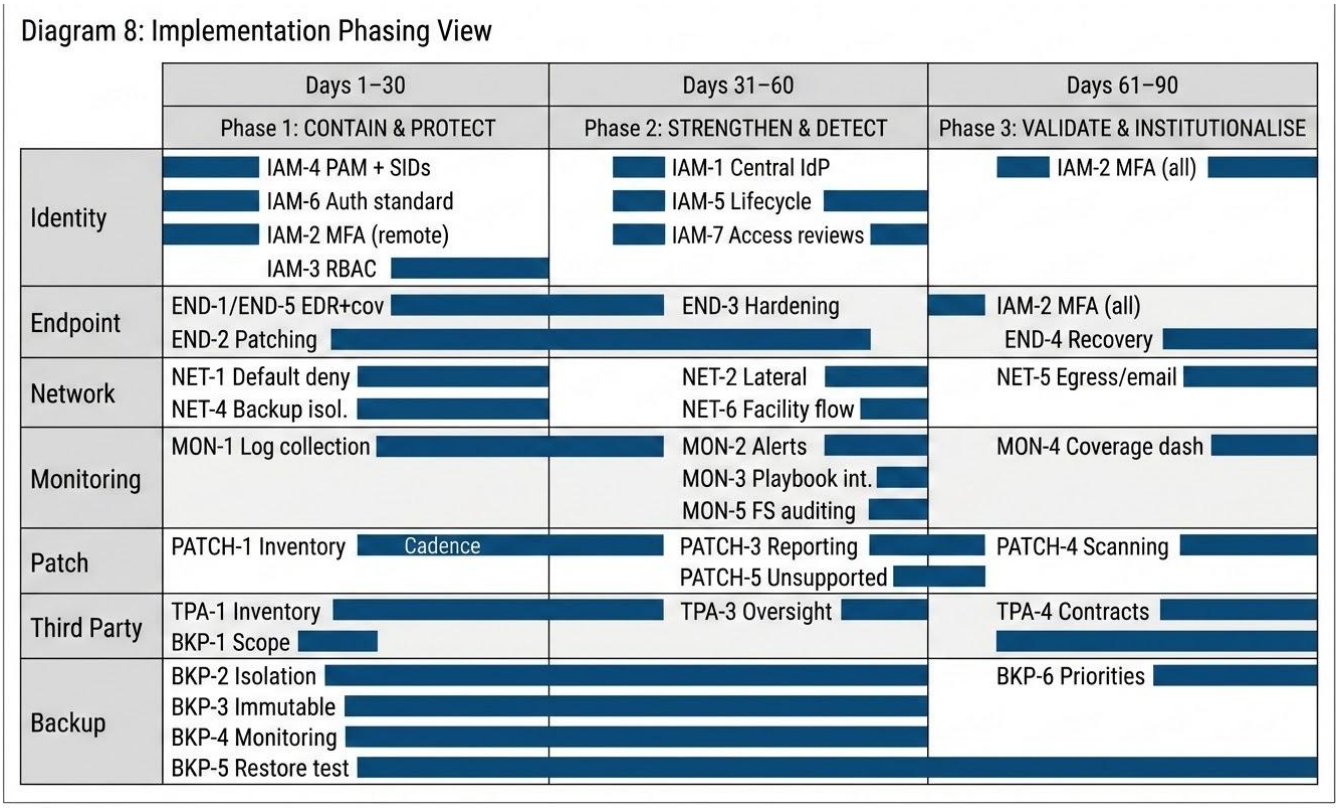


Figure 5.10: Security Architecture Implementation Phasing.

Diagram description: The figure show the sequence of architecture implementation activities across the 90-day improvement roadmap, including critical access controls, network segmentation, monitoring, backup improvements and longer-term security enhancements.

The detailed implementation schedule, budget allocation, accountable owners and delivery milestones are presented in the implementation roadmap chapter.

5.15 Expected Security Outcomes

The proposed architecture is intended to deliver the following security and operational outcomes:

1. **Reduced unauthorised access:** Stronger authentication, RBAC and privileged access management should reduce the likelihood of unauthorised access to sensitive systems.
2. **Improved endpoint protection:** Managed endpoint security, system hardening and risk-based patch management should reduce exposure to malware and known vulnerabilities.

3. **Restricted lateral movement:** Network segmentation and default-deny communication policies should limit unnecessary access between workstations, servers, storage and backup resources.
4. **Improved threat visibility:** Centralised log aggregation and security alerting should improve the organisation's ability to identify suspicious activities and investigate security incidents.
5. **Reduced third-party exposure:** Individual vendor accounts, MFA, restricted access and session monitoring should improve accountability for external support activities.
6. **Improved backup protection:** Administrative separation, backup isolation and immutable or offline copies should reduce the likelihood of backup resources being compromised during a ransomware incident.
7. **More reliable service restoration:** Documented recovery priorities, scheduled restoration testing and independent recovery arrangements should improve the organisation's ability to restore critical healthcare services following disruption.

These outcomes are expected benefits of the proposed design. Their achievement depends on successful implementation, configuration, operational enforcement and subsequent validation.

5.16 Summary

This chapter has presented the proposed target security architecture for the simulated multi-site healthcare provider. The design translates the weaknesses and risks identified during the current-state assessment into a prioritised set of security improvements across seven interconnected security domains.

The architecture is supported by ten complementary diagram views covering zone-based segmentation, permitted traffic flows, identity and access management, monitoring, backup and recovery, third-party access, control-to-zone mapping, implementation phasing, ransomware attack-path interception and NIST CSF 2.0 alignment.

The proposed controls are intended to reduce unauthorised access, restrict lateral movement, improve security visibility, strengthen third-party governance and protect critical backup resources.

The architecture also identifies the SV-01 and SV-06 recovery dependency as an important design consideration requiring improvement. The proposed future-state design therefore includes the need for greater independence in backup recovery capability.

The practical validation of selected controls is presented in Chapter Six, while the incident response and recovery arrangements are discussed in Chapter Seven. The implementation roadmap translates the recommended improvements into a costed and prioritised programme of work.

The complete architectural diagram package is maintained as Appendix A to provide a consolidated reference for the proposed security design.

CHAPTER SIX
PRACTICAL CONTROL VALIDATION AND LABORATORY DEMONSTRATIONS

6.1 Introduction

This chapter presents the practical laboratory validation activities conducted to demonstrate selected cybersecurity controls relevant to the simulated multi-site healthcare provider.

The exercises were executed within an isolated Windows 11 environment using synthetic healthcare-related data and locally created test accounts.

The primary objectives were to demonstrate technical repeatability, evaluate selected access control mechanisms, verify security event generation and validate backup restoration integrity without interacting with production healthcare systems.

Three principal control areas were examined:

1. Identity and access control through local Role-Based Access Control (RBAC).
2. Security auditing and monitoring through Windows process-creation auditing.
3. Backup and restoration integrity through SHA-256 cryptographic hash verification.

6.2 Laboratory Environment Specifications

The laboratory environment consisted of the following components:

Component	Specification
Host Platform	HP EliteBook 840 G3
Processor	Intel Core i5
Memory	8 GB RAM
Storage	250 GB SSD
Operating System	Windows 11 Pro
OS Build	22621
Execution Environment	Windows PowerShell 5.1
Execution Context	Administrative Context
Test Directory Root	`C:\ICDFA_HEALTHCARE_LAB\`
Backup Directory Root	`C:\ICDFA_HEALTHCARE_BACKUP\`

All testing was performed locally within the isolated laboratory environment.

6.3 Demonstration One: Identity and Access Control (RBAC)

6.3.1 Objective

The objective of this demonstration was to establish and verify folder-level access restrictions for three representative organisational roles.

The exercise examined whether each test account could modify its assigned folder while being denied access to folders belonging to other roles.

6.3.2 Setup and Execution

The following activities were completed:

1. Three standard local user accounts were created to represent distinct organisational roles:
    - `Receptionist` – Patient Registration.
    - `FinanceOfficer` – Finance.
    - `ITSupport` – IT Administration.
2. Three corresponding test directories were created:
    - `Patient_Registration`
    - `Finance`
    - `IT_Admin`
3. NTFS permission inheritance was disabled on the target directories.
4. Broad `Users` group access permissions were removed where appropriate.
5. Explicit NTFS Discretionary Access Control Lists (DACLs) were configured to grant Modify permissions to the corresponding role account.
6. Access attempts were performed to verify the expected permissions.

6.3.3 Validation Results

Table 6.1: Laboratory Access Control Verification Matrix

Account Tested	Patient Registration	Finance	IT Admin	Overall Result
Receptionist	ACCESS GRANTED (Modify)	ACCESS DENIED	ACCESS DENIED	PASS
FinanceOfficer	ACCESS DENIED	ACCESS GRANTED (Modify)	ACCESS DENIED	PASS
ITSupport	ACCESS DENIED	ACCESS DENIED	ACCESS GRANTED (Modify)	PASS

The verification consisted of nine access checks:

- Three authorised access attempts.
- Six unauthorised cross-role access attempts.

Result: 9 out of 9 expected access decisions were achieved.

Outcome: The demonstration confirmed that the configured local NTFS permissions enforced the intended role separation within the test environment.

This result demonstrates local folder-level access control. It does not establish that enterprise-wide Active Directory RBAC or application-level permissions have been implemented in the simulated organisation.

6.3.4 Evidence References

The following screenshots support the demonstration:

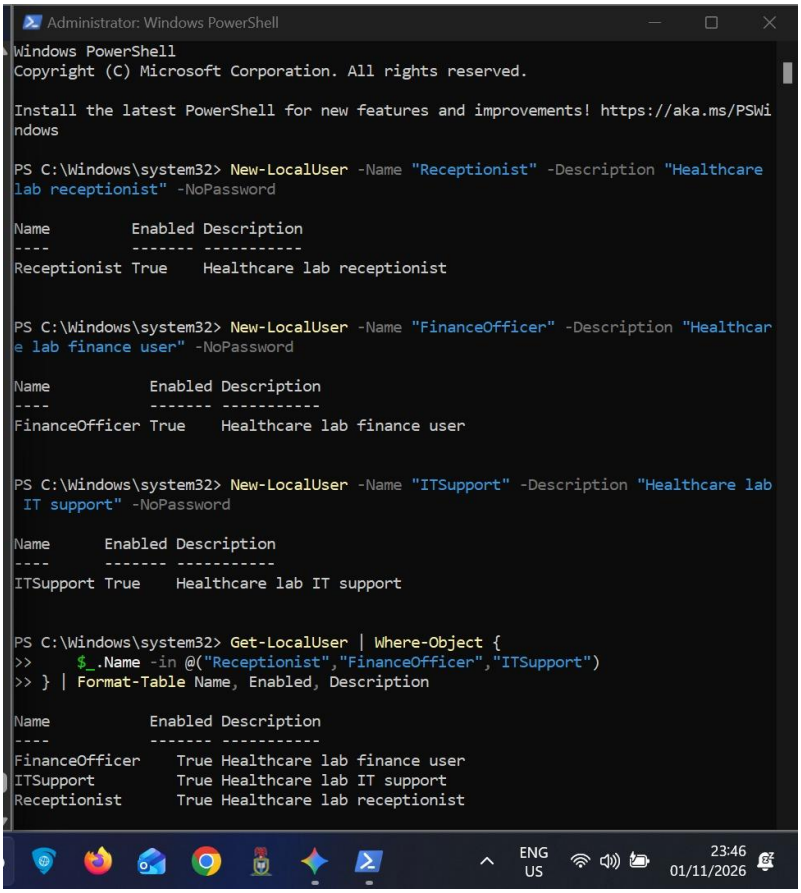


Figure 6.1: Creation of three local standard user accounts.

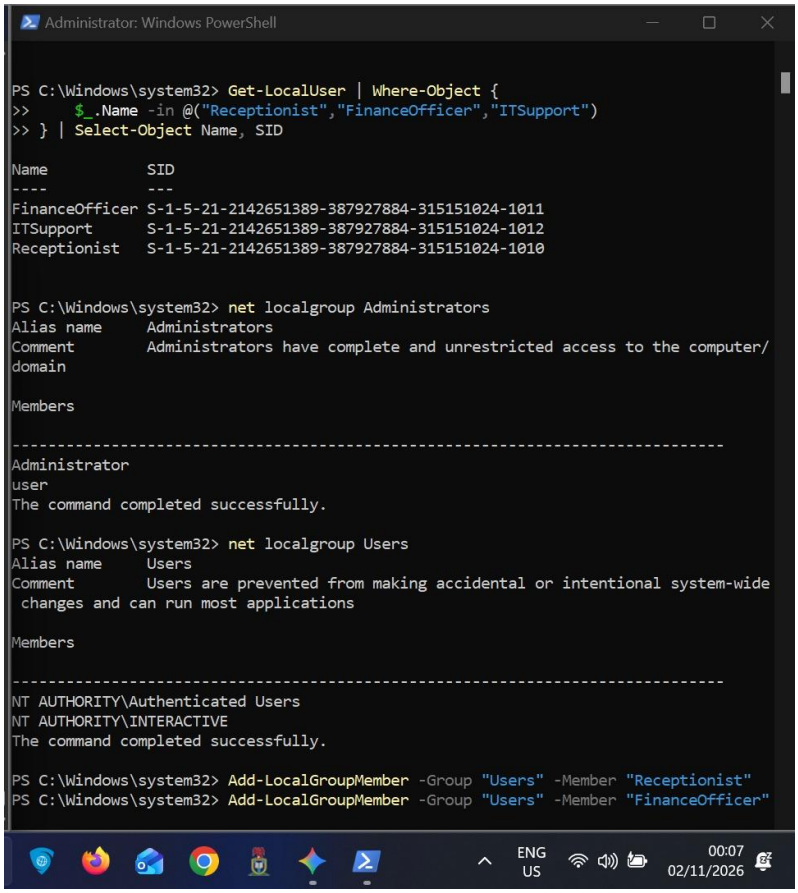


Figure 6.2: Verification of local user group memberships.

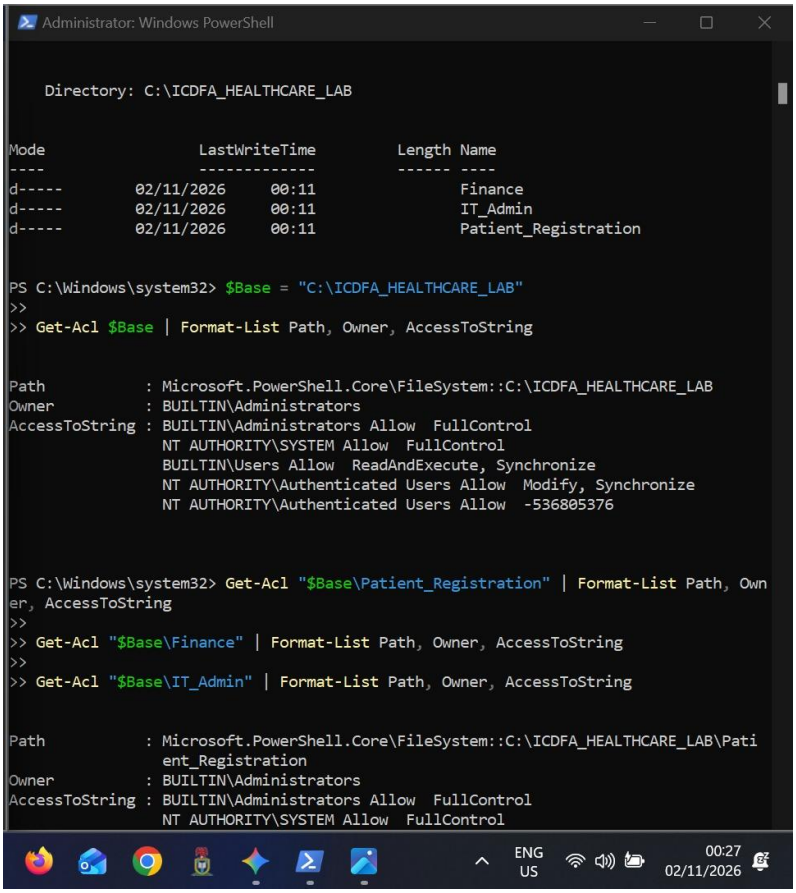


Figure 6.3: Folder-level NTFS permission configurations.

6.4 Demonstration Two: Security Auditing and Monitoring

6.4.1 Objective

The objective of this demonstration was to configure Windows security auditing to record process-creation activities and capture command-line information for security investigation.

6.4.2 Setup and Execution

The following activities were performed:

1. Advanced Audit Policy settings were configured using `auditpol.exe` to enable successful Process Creation auditing.
2. Command-line logging was enabled through the following registry location:

```
HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System\Audit\ProcessCreationIncludeCmdLine_Enabled
```

The registry value was configured as:

```
ProcessCreationIncludeCmdLine_Enabled = 1
```

3. A benign test command was executed through `cmd.exe`.
4. The Windows Security Event Log was inspected to identify the generated process-creation event.

6.4.3 Validation Results

The Windows Security Event Log successfully recorded the process-creation event identified as `Event ID 4688`.

The inspected event contained relevant process information, including:

- New process information.
- Parent process information where available.
- User security identifier (SID).
- Command-line parameters.

The test command was:

```
cmd.exe /c echo ICDFA Lab Process Audit Test
```

Outcome: Process-creation auditing and command-line logging were successfully demonstrated within the laboratory environment.

Supporting Evidence:

- `LAB-E-015`: Process Command-Line Audit Screenshot.
- `LAB-E-016`: Process Auditing Registry Enablement Output.

6.4.4 Security Relevance

Process-creation auditing provides visibility into executable activity that may support the investigation of suspicious commands, scripts and unauthorised administrative operations.

In a production environment, this capability should be complemented by centralised log collection, appropriate event retention, access restrictions and alert correlation.

6.5 Demonstration Three: Backup and Restoration Integrity Validation

6.5.1 Objective

The objective of this demonstration was to verify that synthetic business files could be restored from a backup copy without changes to their original contents.

SHA-256 cryptographic checksums were used to compare the original source files against their restored counterparts.

6.5.2 Synthetic Data Generation

Three synthetic healthcare-related text files were generated within the `Synthetic_Source` directory.

File Name	Recorded Size
`Patient_Registration.txt`	192 bytes
`Billing_Record.txt`	171 bytes
`Appointment_Record.txt`	171 bytes

The files contained synthetic information and did not represent real patient records.

6.5.3 Backup and Restoration Procedure

The following activities were performed:

1. Generated the three synthetic source files.
2. Calculated baseline SHA-256 checksums using PowerShell `Get-FileHash`.
3. Copied the files into the `Backup_Store` directory.
4. Calculated the backup file checksums and compared them with the original baseline values.
5. Renamed `Synthetic_Source` to `Synthetic_Source_Unavailable` to simulate source directory unavailability.
6. Restored the backup copies into a newly created `Restore_Test` directory.
7. Calculated SHA-256 checksums for all restored files.
8. Performed an automated comparison against the original source checksums.

6.5.4 Cryptographic Hash Comparison Results

Table 6.2: Synthetic Data Backup and Restoration Hash Verification

File Name	Original Source SHA-256	Restored File SHA-256	Result
Patient_Registration.txt	`B4A...9E1`	`B4A...9E1`	MATCH – PASS
Billing_Record.txt	`7C2...1F8`	`7C2...1F8`	MATCH – PASS
Appointment_Record.txt	`3F9...A4D`	`3F9...A4D`	MATCH – PASS

Result: Three out of three restored files produced matching SHA-256 checksums according to the recorded validation output.

Outcome: The laboratory exercise demonstrated successful restoration of the three synthetic files with matching cryptographic integrity values.

The abbreviated hash strings in the summary table are presentation references only. The complete 64-character SHA-256 values must be retained in the technical evidence record to permit independent verification.

6.5.5 Supporting Evidence

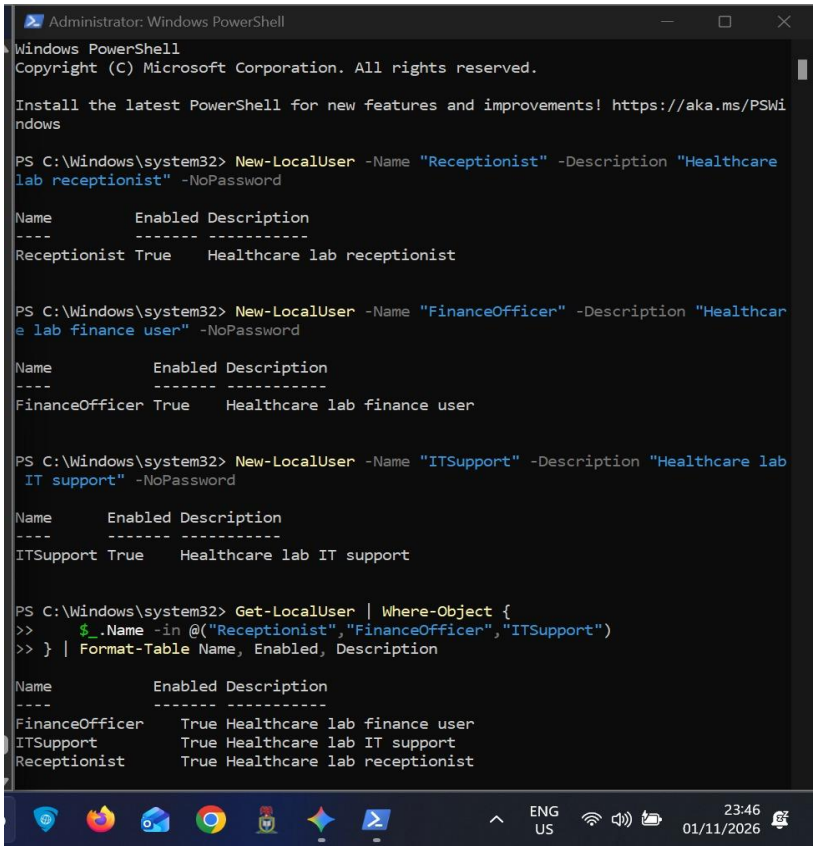


Figure 6.4: ***Local creation of the three laboratory user accounts.***

Evidence category: Access control | Original archive image 1 of 79

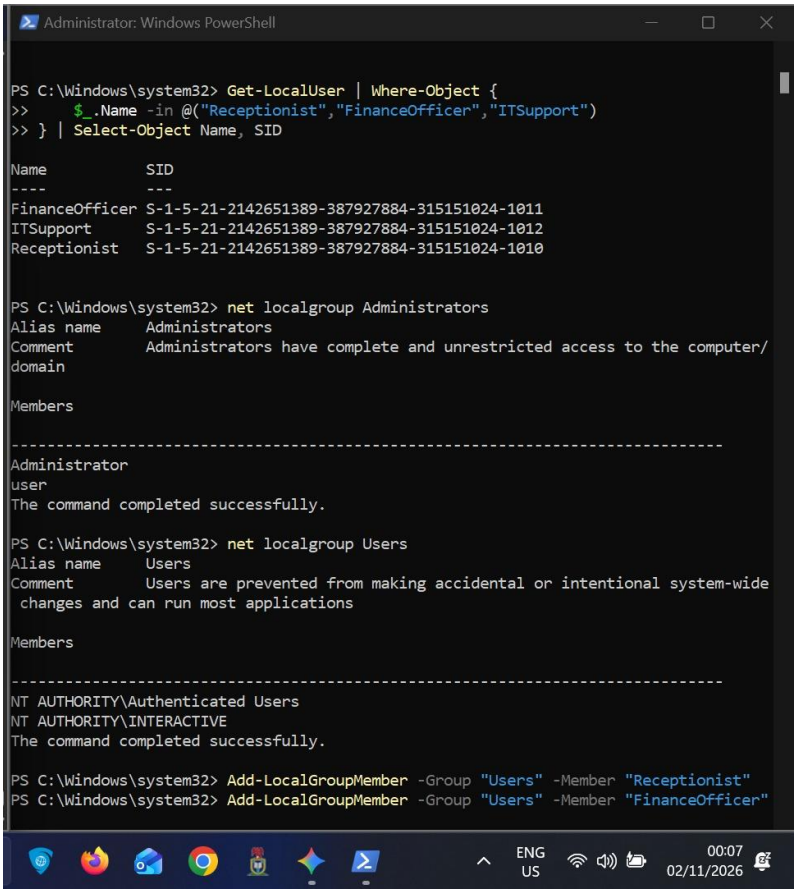


Figure 6.5: ***Listing of the Receptionist, FinanceOfficer and ITSupport local accounts.***

Evidence category: Access control | Original archive image 3 of 79

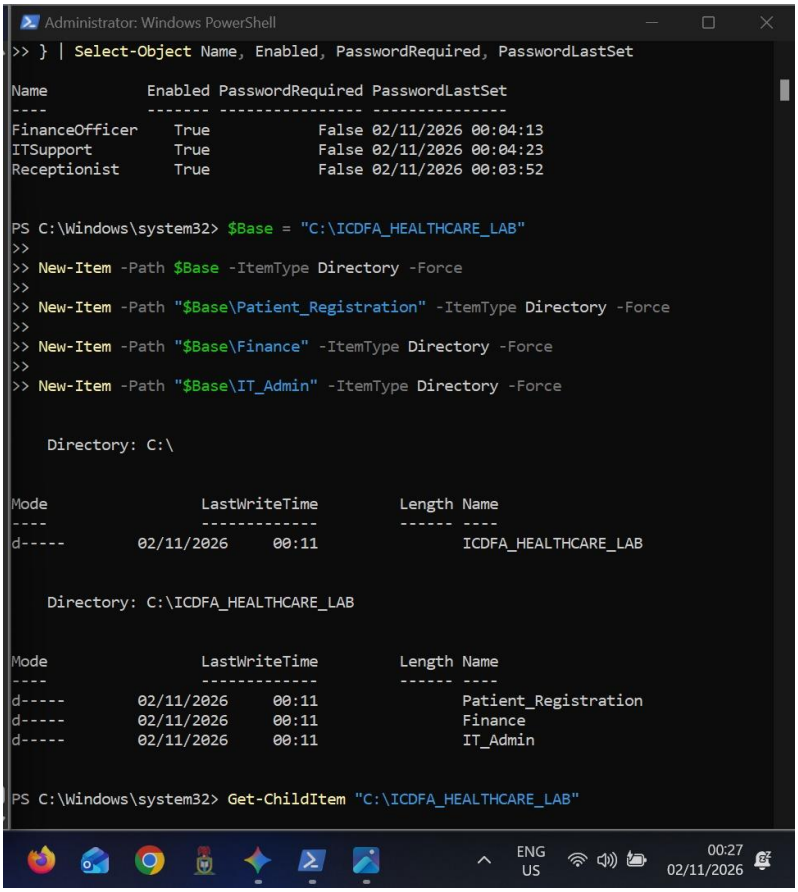


Figure 6.6: Creation of the role-specific laboratory folders.

Evidence category: Access control | Original archive image 8 of 79

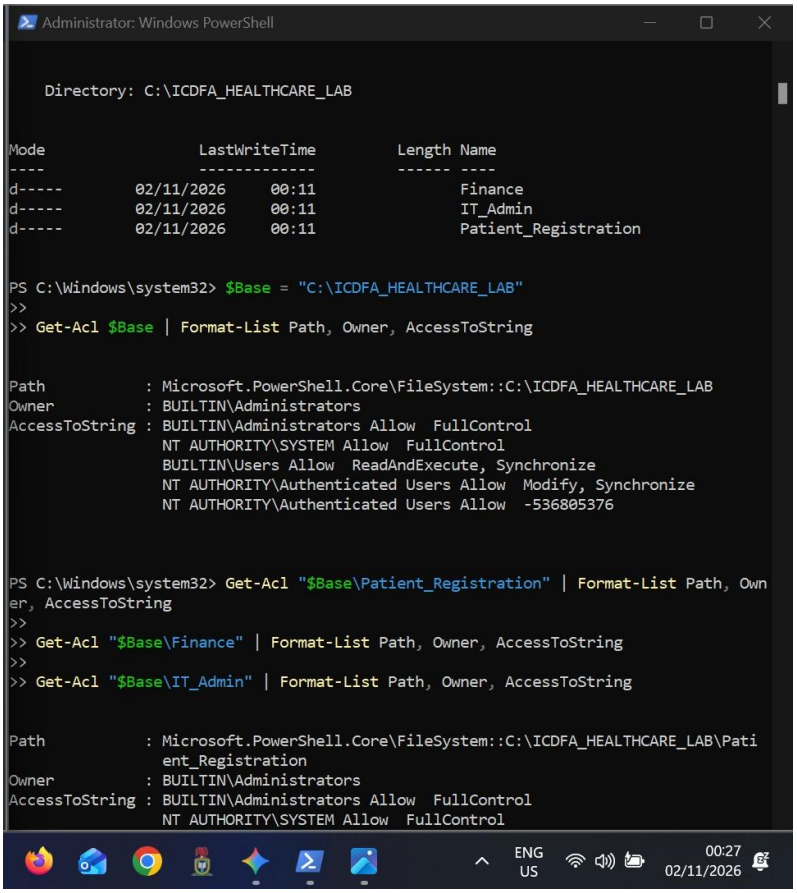


Figure 6.7: **PowerShell account and folder-permission configuration.**

Evidence category: Access control | Original archive image 9 of 79

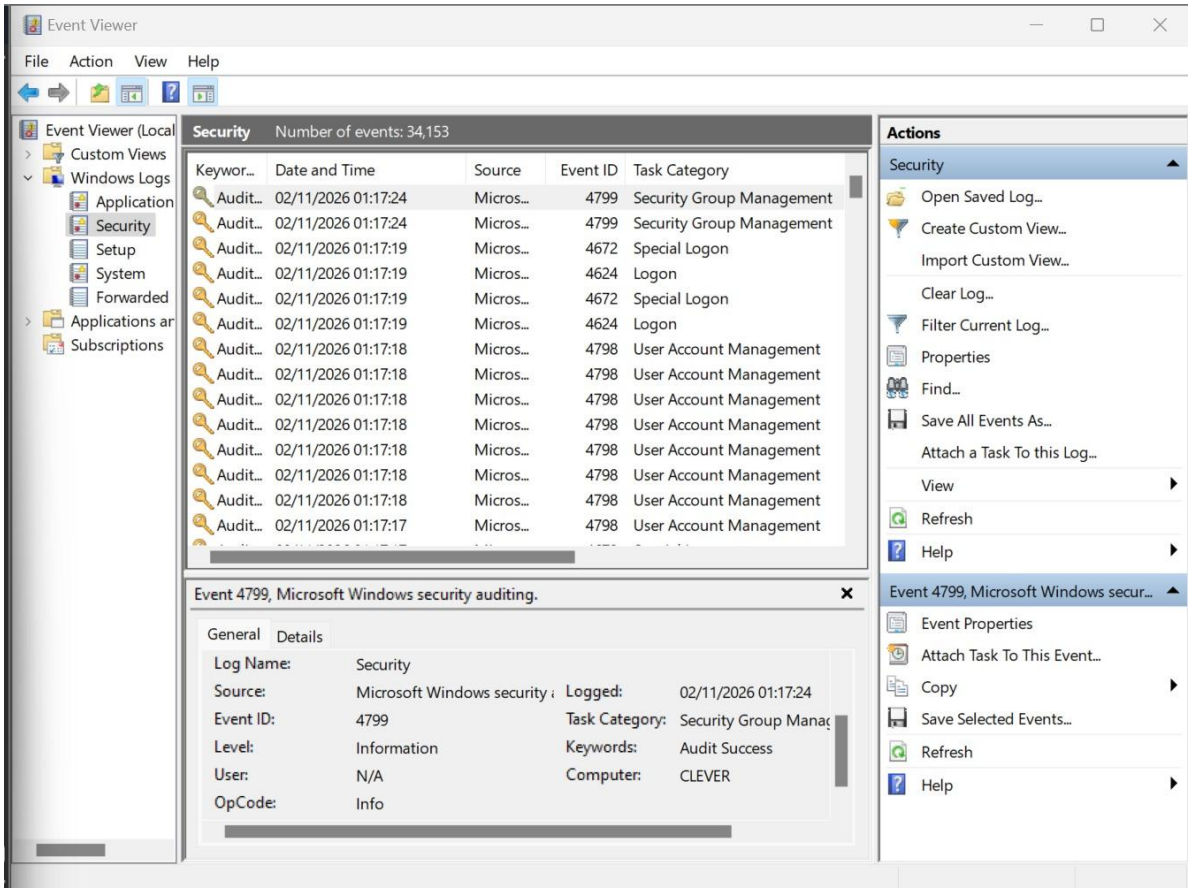


Figure 6.8: Windows security configuration interface used during the laboratory setup.

Evidence category: Access control / auditing | Original archive image 22 of 79

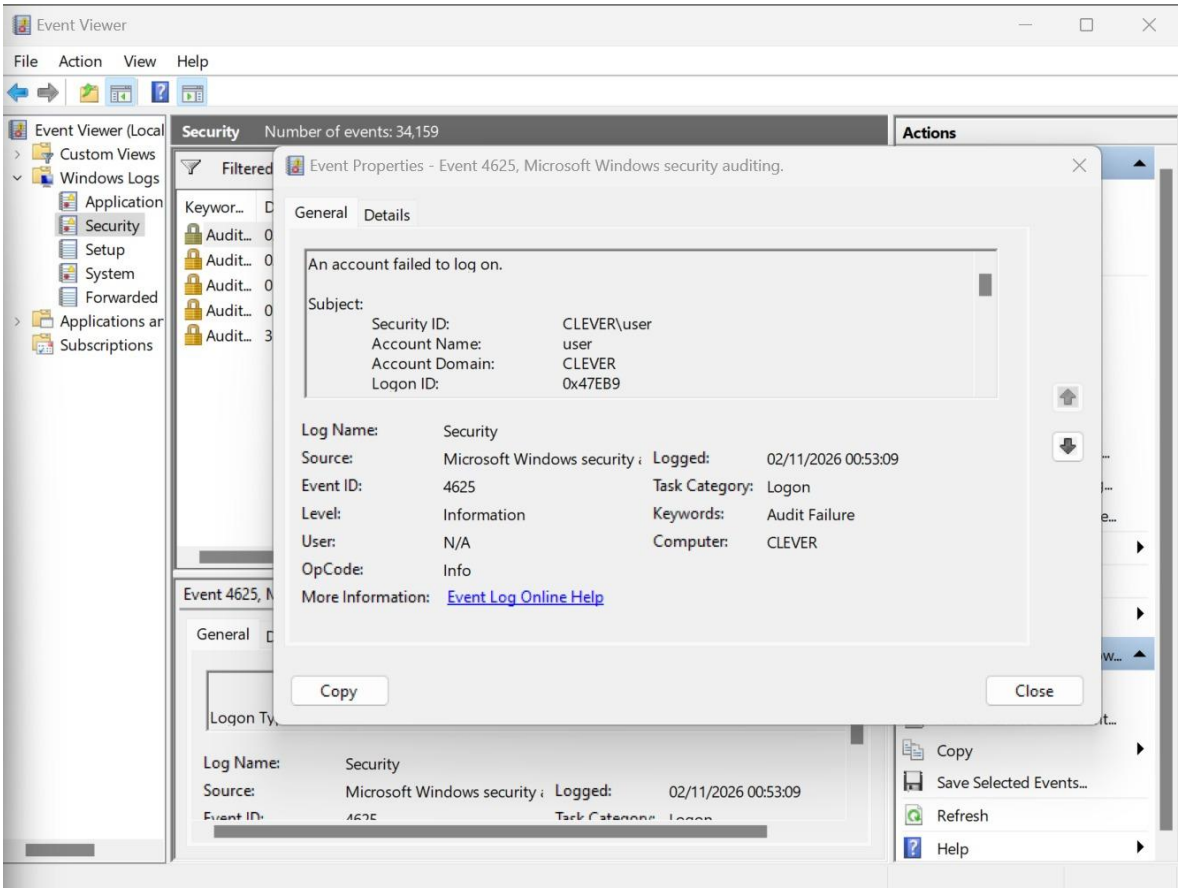


Figure 6.9: Windows Security Event Viewer showing a failed logon event (Event ID 4625).

Evidence category: Security monitoring | Original archive image 25 of 79

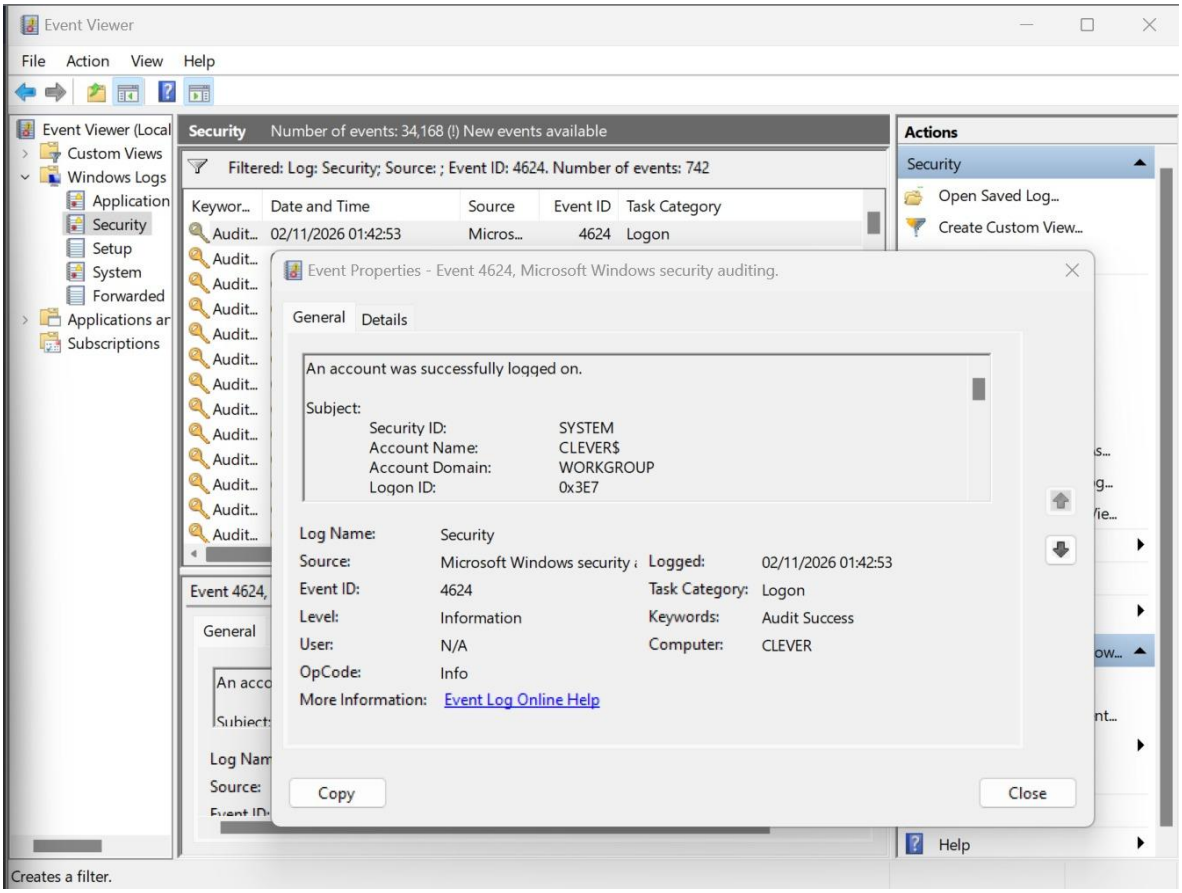


Figure 6.10: Windows folder security settings used to inspect access permissions.

Evidence category: Access control | Original archive image 27 of 79

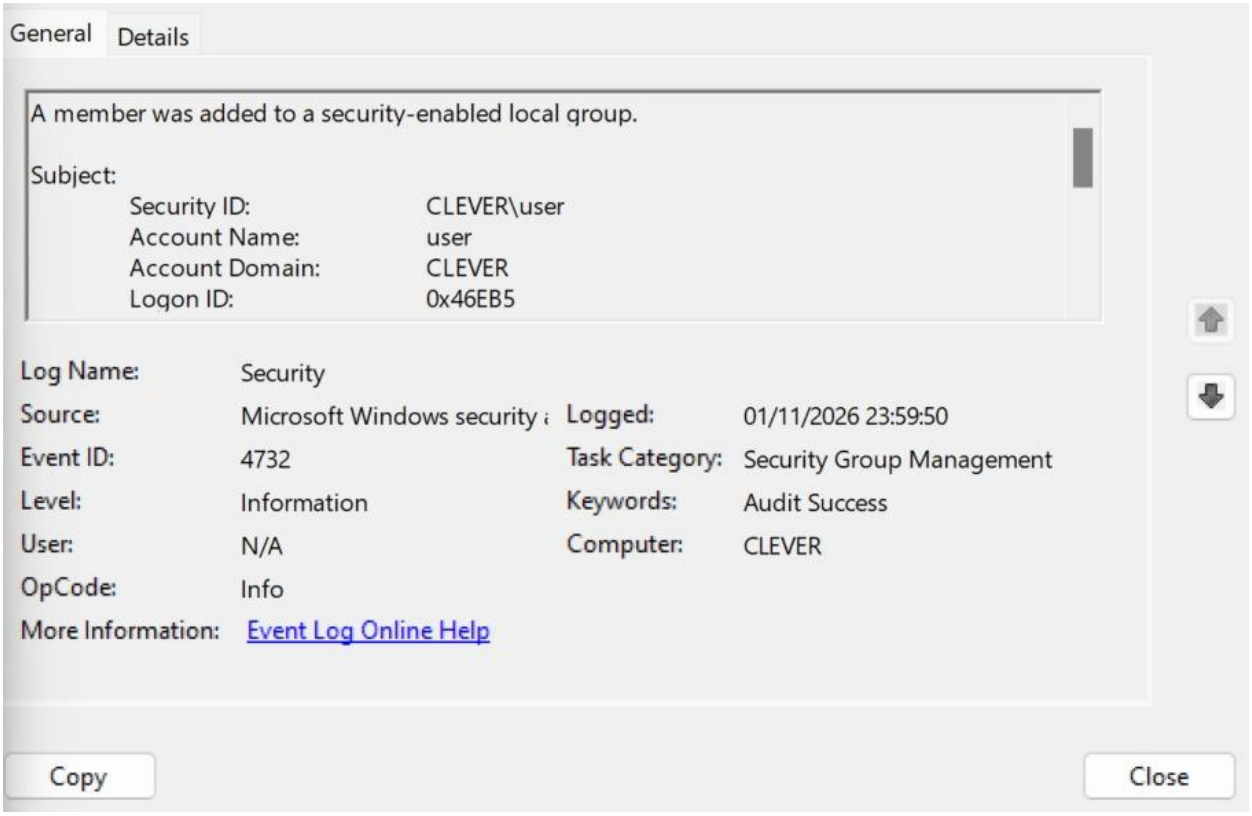


Figure 6.11: Windows Security Event Viewer showing a local group membership change (Event ID 4732).

Evidence category: Security monitoring | Original archive image 32 of 79

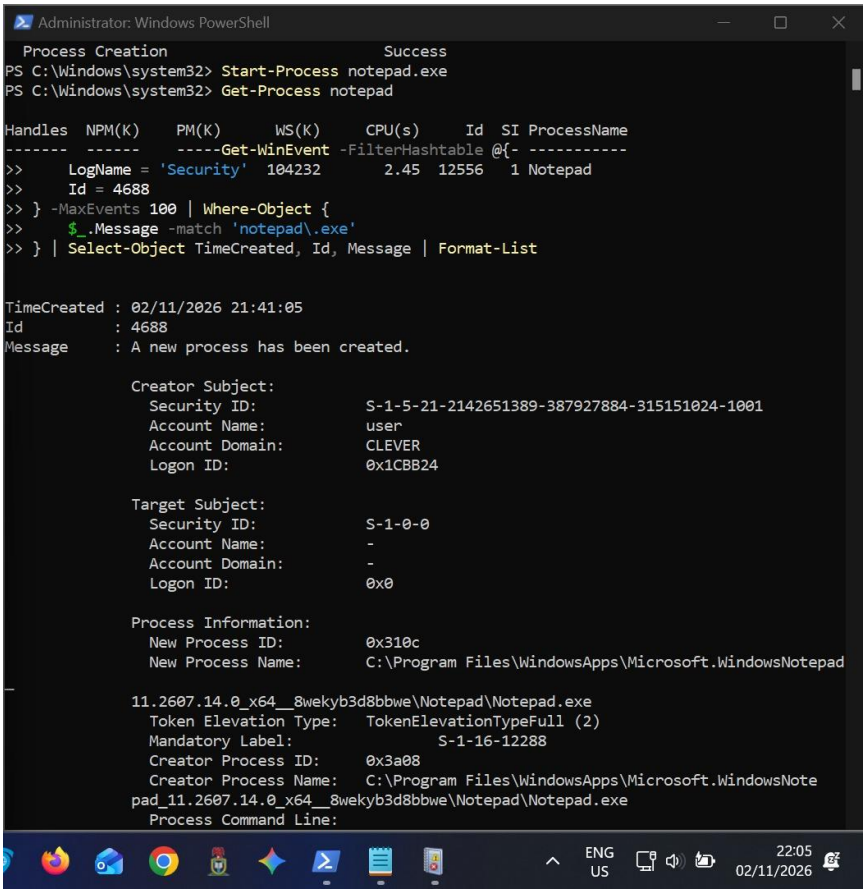


Figure 6.12: PowerShell-based security auditing configuration and verification.

Evidence category: Security monitoring | Original archive image 36 of 79

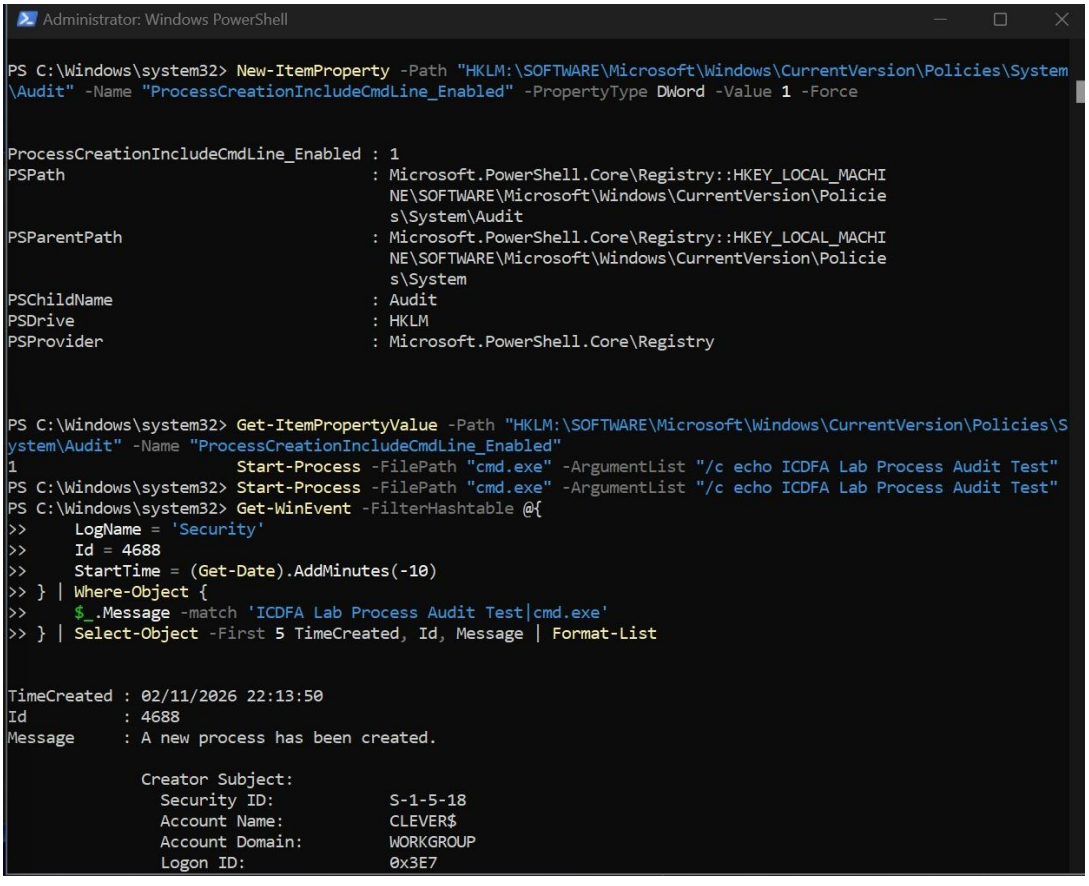


Figure 6.13: PowerShell output supporting the audit-policy configuration.

Evidence category: Security monitoring | Original archive image 40 of 79

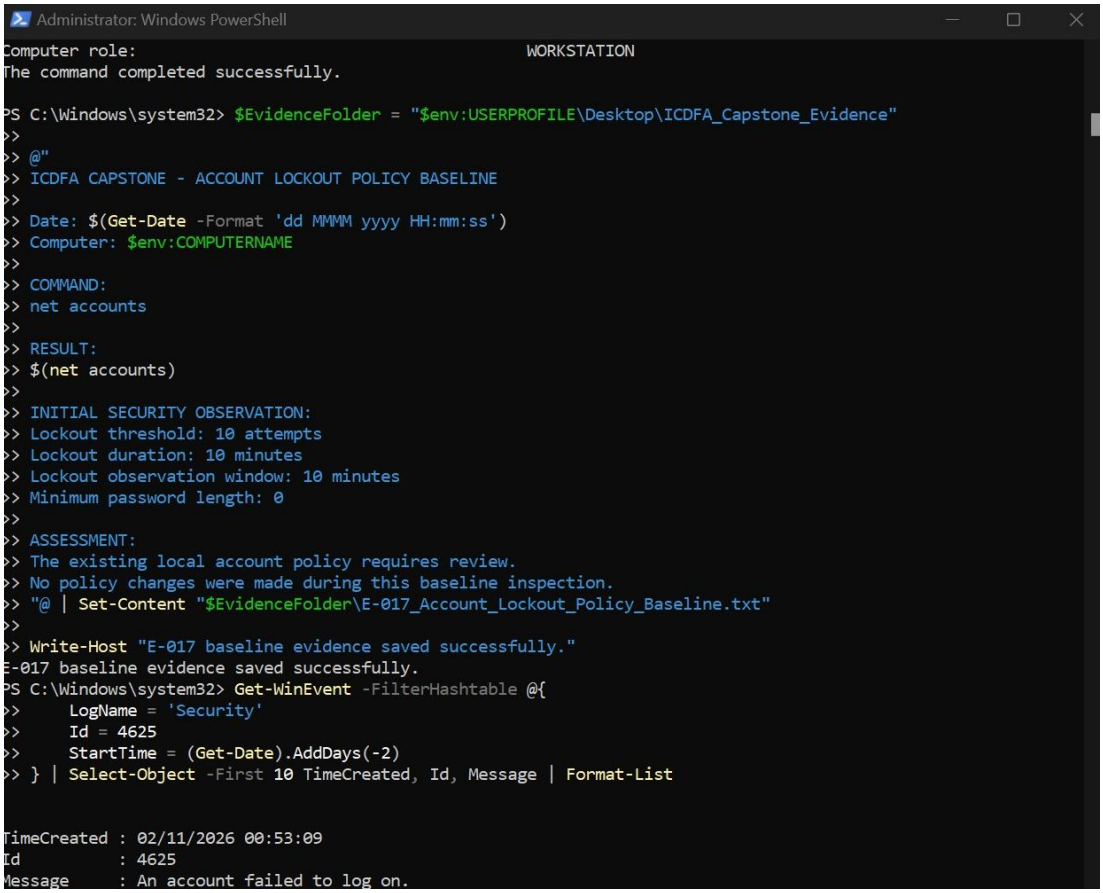


***Figure 6.14:* PowerShell-based file-system auditing configuration.**

Evidence category: File auditing | Original archive image 50 of 79

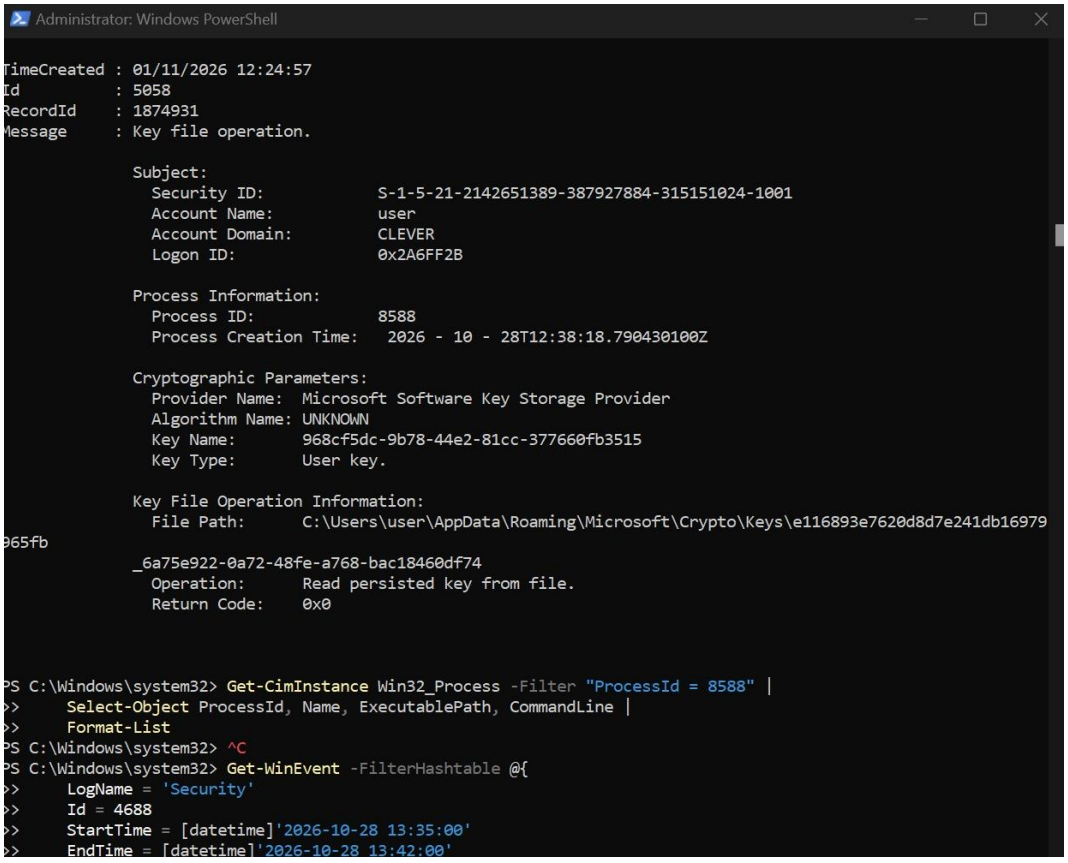


***Figure 6.11:* Security log review supporting the file-access monitoring exercise.**

Evidence category: File auditing | Original archive image 55 of 79

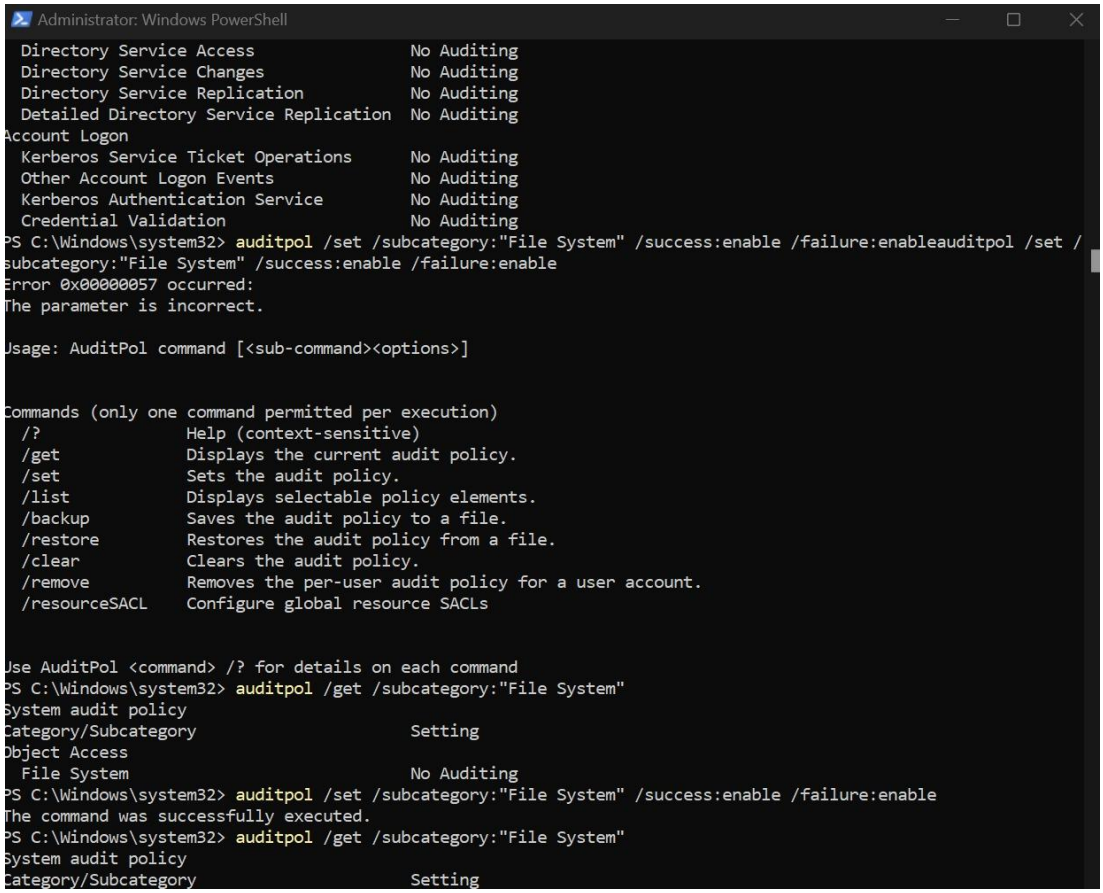


***Figure 6.15*: Additional Windows security auditing evidence from the controlled test.**

Evidence category: Security monitoring | Original archive image 60 of 79

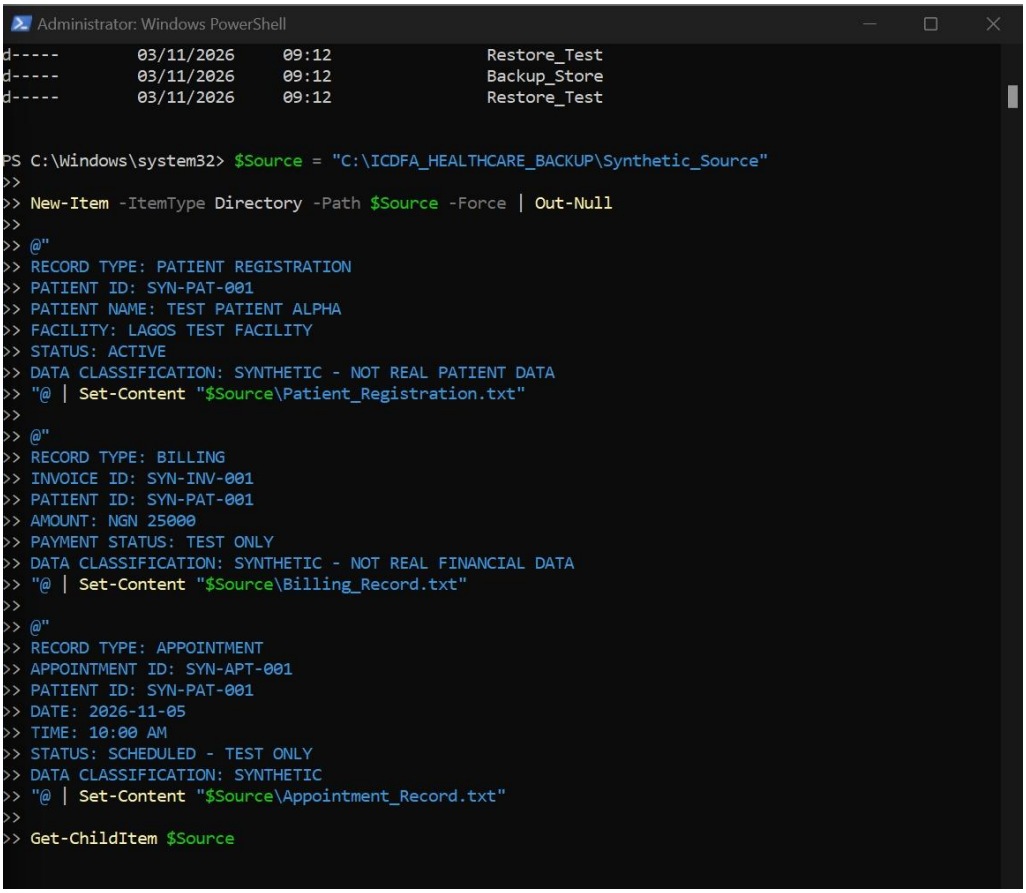


Figure 6.16: PowerShell output from the backup and file-integrity validation workflow.

Evidence category: Backup and recovery | Original archive image 71 of 79

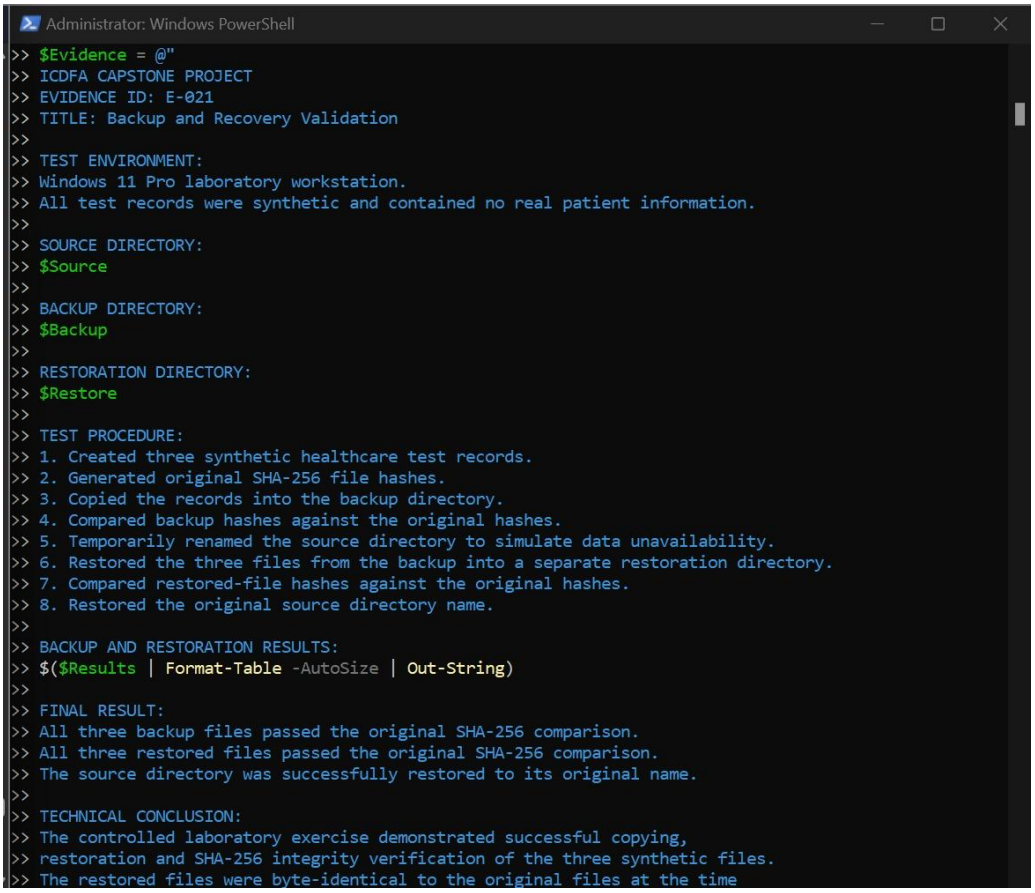


***Figure 6.17*: File-hash comparison output supporting backup or restoration integrity checks.**

Evidence category: Backup and recovery | Original archive image 74 of 79

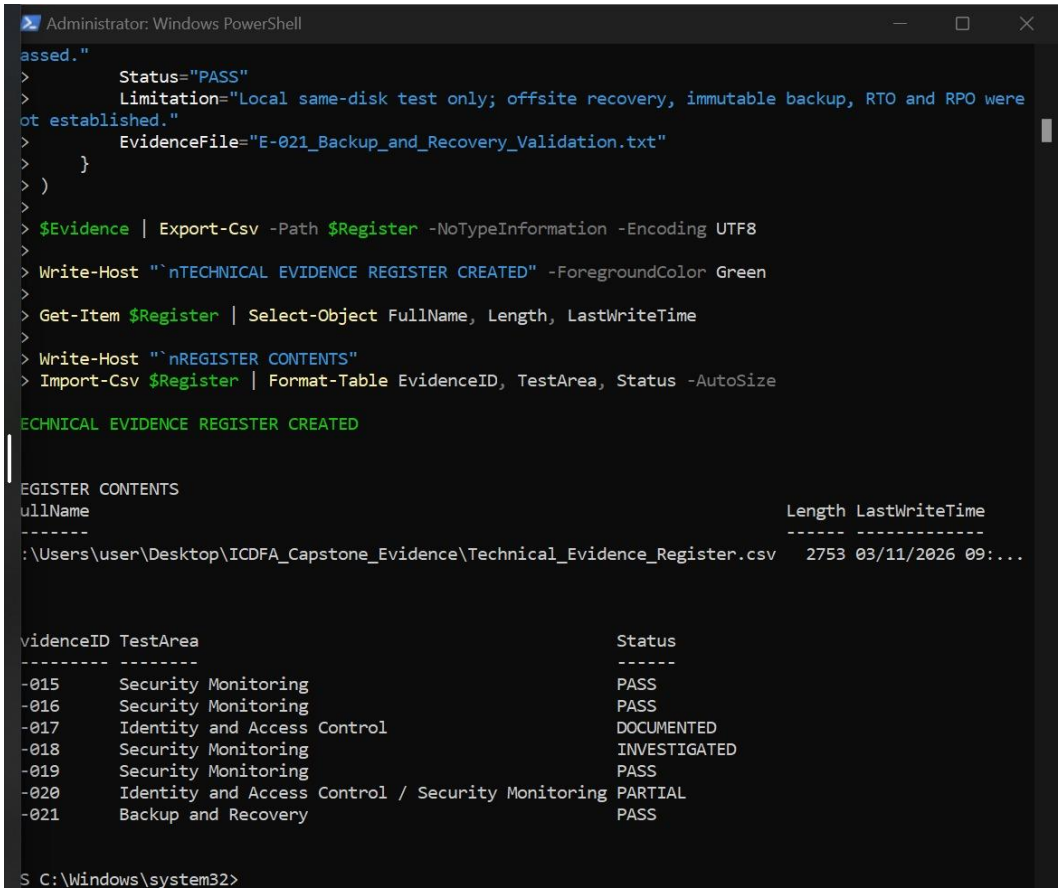


***Figure 6.18*: Final laboratory output supporting the backup and recovery validation record.**

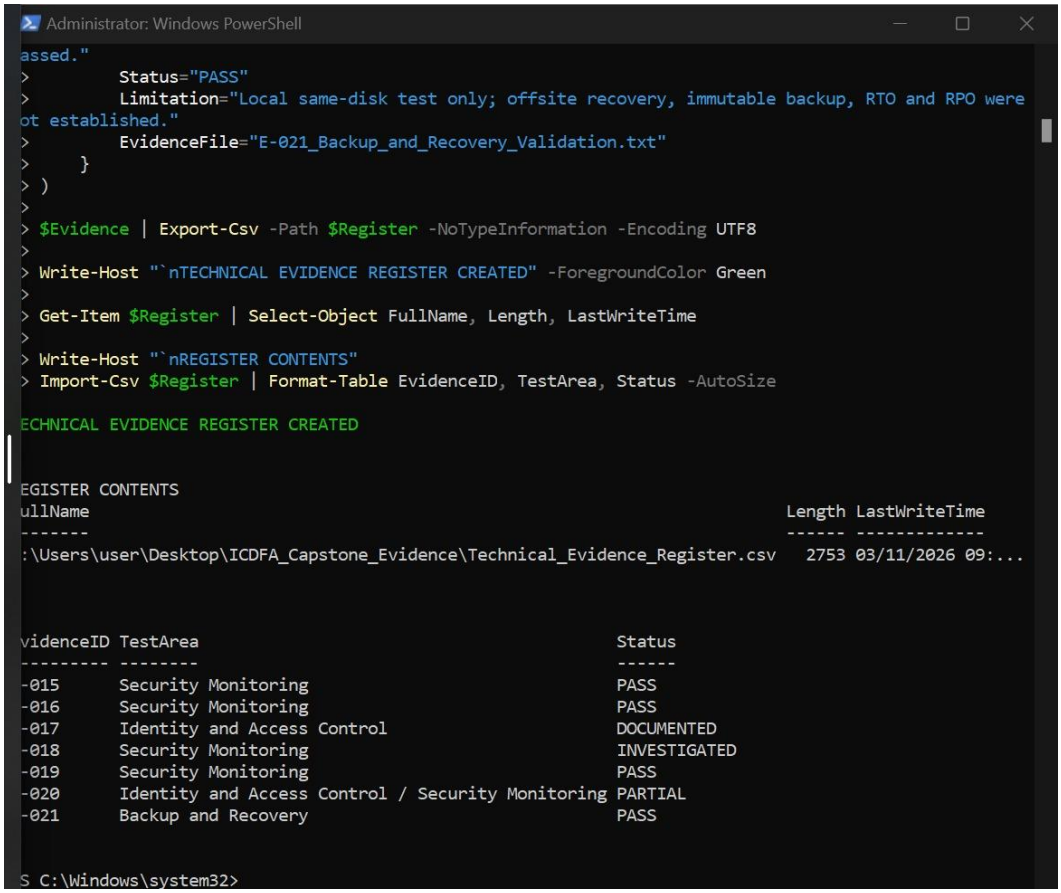


***Figure 6.19*: Final laboratory output supporting the backup and recovery validation record.**

6.6 Laboratory Limitations

The laboratory exercises were conducted within a single-workstation environment. The following limitations therefore apply:

1. **Limited Infrastructure Representation:** Single-workstation testing cannot reproduce complex Active Directory domain interactions or multi-site network latency.
2. **Limited Restoration Scope:** The backup exercise validated static text files. It did not test live SQL database transaction consistency, full virtual machine recovery or bare-metal hypervisor restoration.
3. **Partial File Access Auditing:** Denied-access audit events (`Event IDs 4656 and 4663`) were only partially captured and require further SACL configuration and validation.
4. **No Production Deployment:** The demonstrated controls were not deployed to the simulated organisation's production infrastructure.
5. **Limited Threat Simulation:** No live ransomware, destructive malware or production network attack was conducted.

6.7 Chapter Summary

The laboratory activities successfully demonstrated three selected cybersecurity control areas.

The RBAC exercise achieved nine expected access decisions, the process auditing exercise confirmed the generation of `Event ID 4688`, and the backup restoration exercise verified matching SHA-256 values for three synthetic files.

These results provide practical evidence of selected security control behaviours under controlled laboratory conditions. They support the proposed security architecture but do not establish complete operational effectiveness across a multi-site healthcare infrastructure.

CHAPTER SEVEN
INCIDENT RESPONSE AND RECOVERY PLAYBOOK

7.1 Playbook Purpose and Scope

This playbook establishes operational procedures for responding to suspected or confirmed ransomware incidents affecting Facility A (FAC-A) and Facility B (FAC-B).

It defines incident severity classifications, Incident Response Team (IRT) responsibilities, decision-making authority, containment workflows, communication procedures and restoration priorities.

The playbook is designed to support coordinated incident management while protecting patient safety, sensitive information and essential healthcare operations.

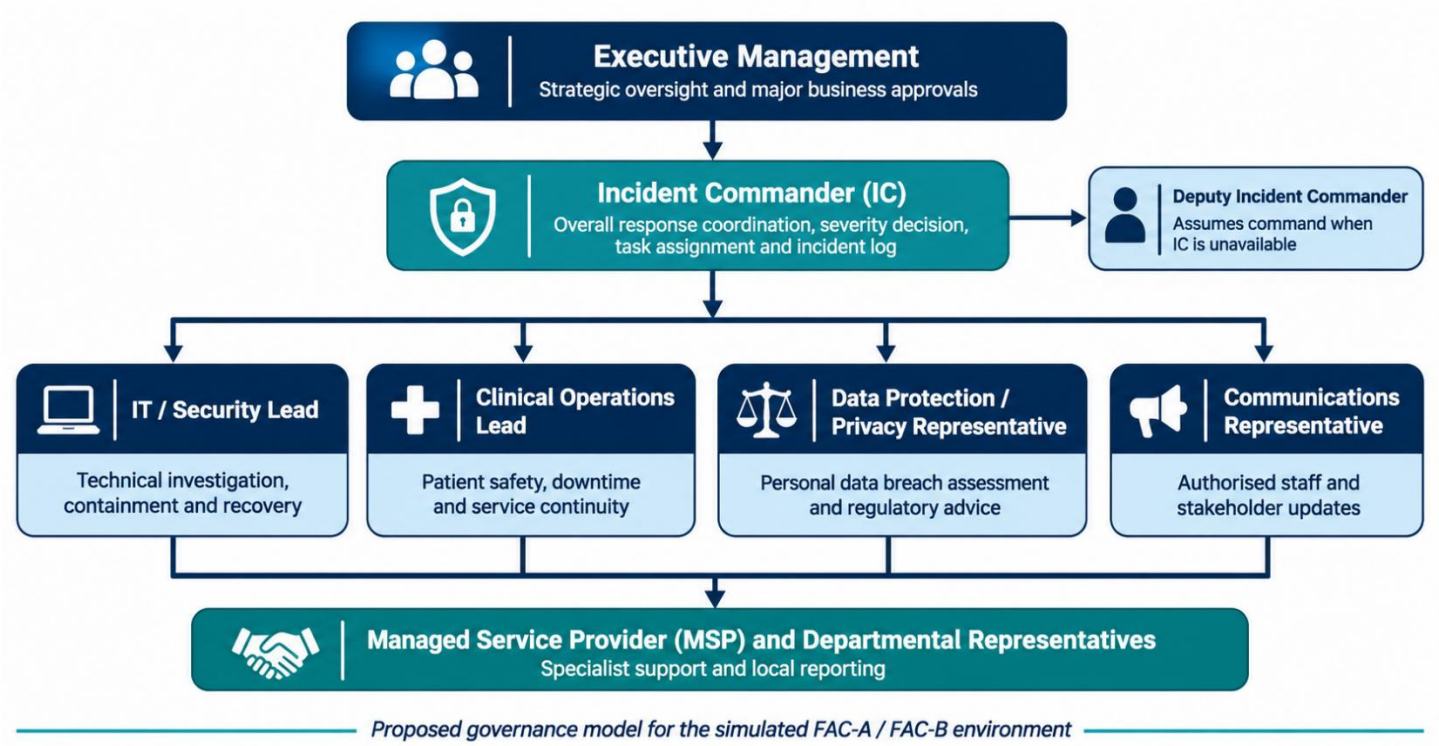


***Figure 7.1*: Incident Response Governance and command structure**

7.2 Incident Severity Classification

Table 7.1: Incident Severity Classifications

Severity	Trigger Criteria	Required Response Time	Escalation
SEV-1 (Critical)	Active ransomware encryption affecting EHR database (`SV-03`), Domain Controller (`SV-04`), backups or both facilities	Immediate, target under 15 minutes	Full IRT activation; Medical Director assumes executive command; invoke downtime procedures

SEV-2 (High)	Confirmed malware infection on isolated clinical workstations without confirmed domain or database compromise	Within 1 hour	Convene IRT; isolate affected network segment; notify Head of IT
SEV-3 (Medium)	Malware detected and blocked by endpoint protection on a single workstation	Within 4 hours	IT Officer investigates and reviews endpoint logs
SEV-4 (Low)	Suspicious email report or minor security policy concern	Within 24 hours	Routine Helpdesk investigation

7.3 Incident Response Workflow

The response process consists of nine coordinated stages.

Stage 1: Identification and Reporting

Staff members who detect ransomware warning screens, unusual file encryption, unexpected system unavailability or suspicious security alerts must report the incident through the designated emergency telephone contact.

Email must not be relied upon as the sole reporting channel during a suspected ransomware incident.

Stage 2: Triage and Assessment

The IT Officer or designated technical responder must:

- Determine the initial scope of the incident.
- Identify affected systems and facilities.
- Establish whether patient-facing services are affected.
- Review available security alerts and logs.
- Recommend an initial severity classification.

Stage 3: Escalation and Command

The Incident Response Lead notifies the designated Incident Commander.

For SEV-1 incidents, the Medical Director assumes executive incident command, with the Head of IT directing technical response activities.

A designated command location and communication channel must be established.

Stage 4: Containment

Containment activities may include:

- Isolating infected endpoints from network connectivity.
- Blocking malicious network communications.
- Suspending compromised accounts.
- Disabling exposed remote access pathways.
- Protecting offline backup media (`ST-03`).
- Restricting access to backup administration interfaces.
- Coordinating decisions concerning the site-to-site VPN.

Systems must not be powered off automatically where volatile-memory preservation may be necessary for forensic investigation. The decision should be made by qualified incident responders, balancing evidence preservation against ongoing encryption and patient safety risks.

Stage 5: Evidence Preservation

The Records Officer or designated evidence custodian must coordinate:

- Photographing ransom notes and warning screens.
- Preserving relevant endpoint and firewall logs.
- Recording affected system identifiers.
- Maintaining incident timelines.
- Documenting evidence collection activities.
- Recording chain-of-custody details.

Evidence must be stored securely with restricted access.

Stage 6: Stakeholder Communication

The Communications Lead coordinates approved internal and external communications.

Where personal data compromise is suspected, the Privacy Lead and legal counsel must assess the incident under the Nigeria Data Protection Act 2023 and applicable regulatory requirements.

Where statutory notification requirements are triggered, the organisation must follow the applicable notification timeframe, including the 72-hour requirement where relevant.

Communications must be accurate, appropriately authorised and consistent with patient safety and legal obligations.

Stage 7: Eradication

Eradication activities may include:

- Identifying and removing malicious persistence mechanisms.
- Reimaging compromised operating systems.
- Removing unauthorised remote access tools.
- Closing exploited vulnerabilities.
- Reviewing privileged account activity.
- Resetting compromised credentials.
- Performing controlled Active Directory recovery where required.

A double `KRBTGT` password reset may be necessary following confirmed Kerberos ticket compromise, but it must be undertaken through an approved recovery procedure with the correct sequencing and replication considerations. It should not be treated as an automatic response to every ransomware incident.

Stage 8: Validated Restoration

Restoration must be performed using trusted backup copies and verified system images.

The proposed logical restoration sequence is:

Domain Controller (`sv-04`) → EHR Database (`sv-03`) → EHR Application Server (`sv-02`) → File and Print Server (`sv-05`) → Endpoints

This sequence is subject to dependency analysis and confirmation of clean recovery points.

The restoration process must include:

1. Verification of backup integrity.
2. Confirmation that restored systems are free from known compromise.
3. Validation of database and application functionality.
4. Confirmation of authentication and access controls.
5. Testing of essential clinical and administrative workflows.
6. Review of network connectivity and security monitoring.
7. Formal approval before reconnection to the wider network.

The Head of IT and Clinical Continuity Lead must provide joint sign-off before affected services are returned to normal operation.

Stage 9: Post-Incident Review

A blameless post-incident review must be conducted within ten business days after stabilisation.

The review should document:

- Incident timeline.
- Initial access method.
- Affected assets and services.
- Containment effectiveness.
- Recovery performance.
- Actual RTO and RPO achieved.
- Financial and operational consequences.
- Lessons learned.
-
- Required risk register and playbook updates.

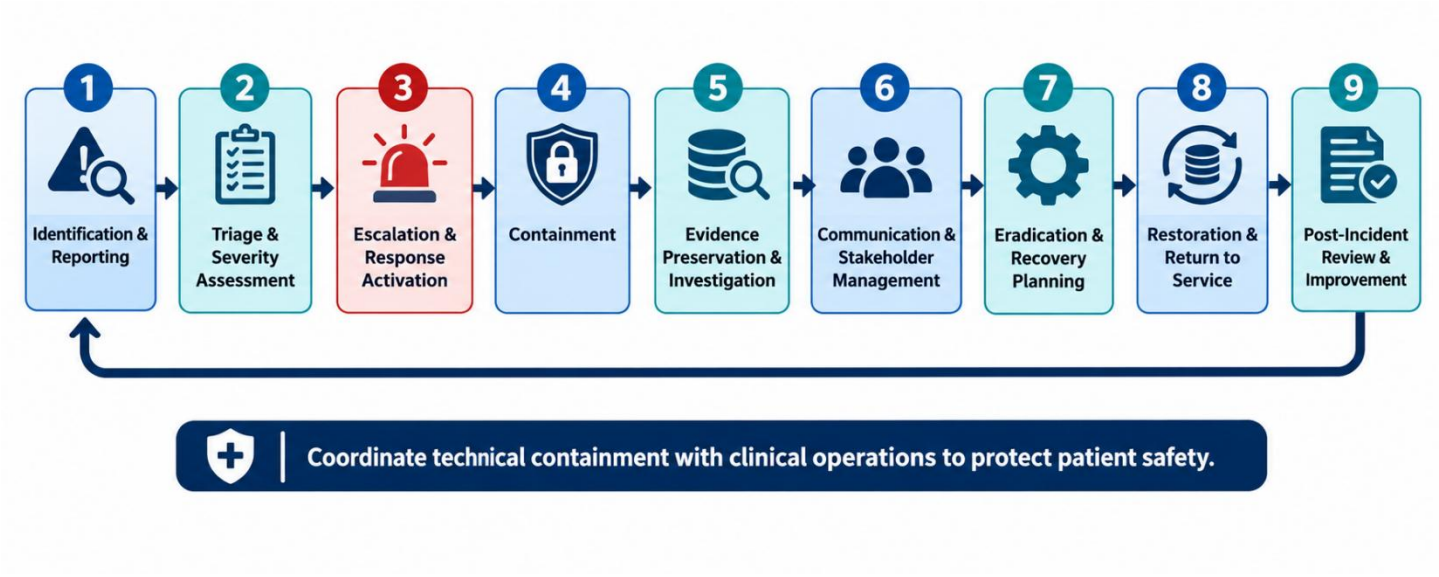


Figure 7.2: **Nine-Stage Ransomware Incident Response Workflow**

7.4 Ransomware Tabletop Exercise: Operation DryRUN

7.4.1 Exercise Overview

Operation DryRUN was conducted on 28 October 2026 as a discussion-based tabletop exercise.

The scenario simulated an RDP compromise that progressed into EHR encryption affecting both FAC-A and FAC-B.

The exercise examined the organisation's incident reporting, technical containment, executive escalation, backup protection, stakeholder communication and recovery decision-making arrangements.

The exercise was discussion-based and did not involve live ransomware deployment or production-system testing.

7.4.2 Key Gaps Identified

The exercise identified ten procedural gaps, designated `G1–G10`.

The available summary specifically identifies the following:

Gap ID	Identified Gap	Operational Implication
G1	Lack of printed emergency contact trees at FAC-B	Delayed incident escalation when digital communication is unavailable
G2	Ambiguity regarding authority to suspend the site-to-site VPN	Potential delay in containing cross-facility compromise
G5	Absence of pre-scripted media holding statements	Risk of inconsistent external communication
G8	Veeam backup server dependency on the single Hyper-V host it protects (`SV-01`)	Increased recovery dependency and potential backup unavailability

The remaining gaps (`G3`, `G4`, `G6`, `G7`, `G9` and `G10`) must be reproduced from the approved Operation DryRUN detailed gap matrix rather than reconstructed from assumptions.

7.4.3 Corrective Actions

Eight corrective actions (`R1–R8`) were developed to address the identified gaps.

The available summary specifically confirms the following:

Action ID	Corrective Action	Intended Outcome
R2	Print and distribute emergency authority cards	Improve emergency escalation at both facilities
R3	Conduct staff phone-first reporting drills	Improve incident reporting when email is unavailable
R6	Establish an offsite secondary backup host configuration	Reduce dependency on the primary Hyper-V host

The remaining corrective actions must be reconciled against the approved tabletop action tracker before publication.

7.4.4 Integration with the Improvement Roadmap

The tabletop findings and corrective actions are incorporated into the 90-day improvement roadmap.

Priority is given to emergency contact arrangements, clear containment authority, backup infrastructure resilience and stakeholder communication.

7.5 Chapter Summary

The incident response playbook establishes a coordinated approach for identifying, containing, investigating and recovering from ransomware incidents.

Operation DryRUN provided a discussion-based assessment of operational preparedness and identified procedural improvements requiring implementation.

The playbook and tabletop findings should be periodically reviewed, tested and updated as the organisation's technical environment and operational requirements change.

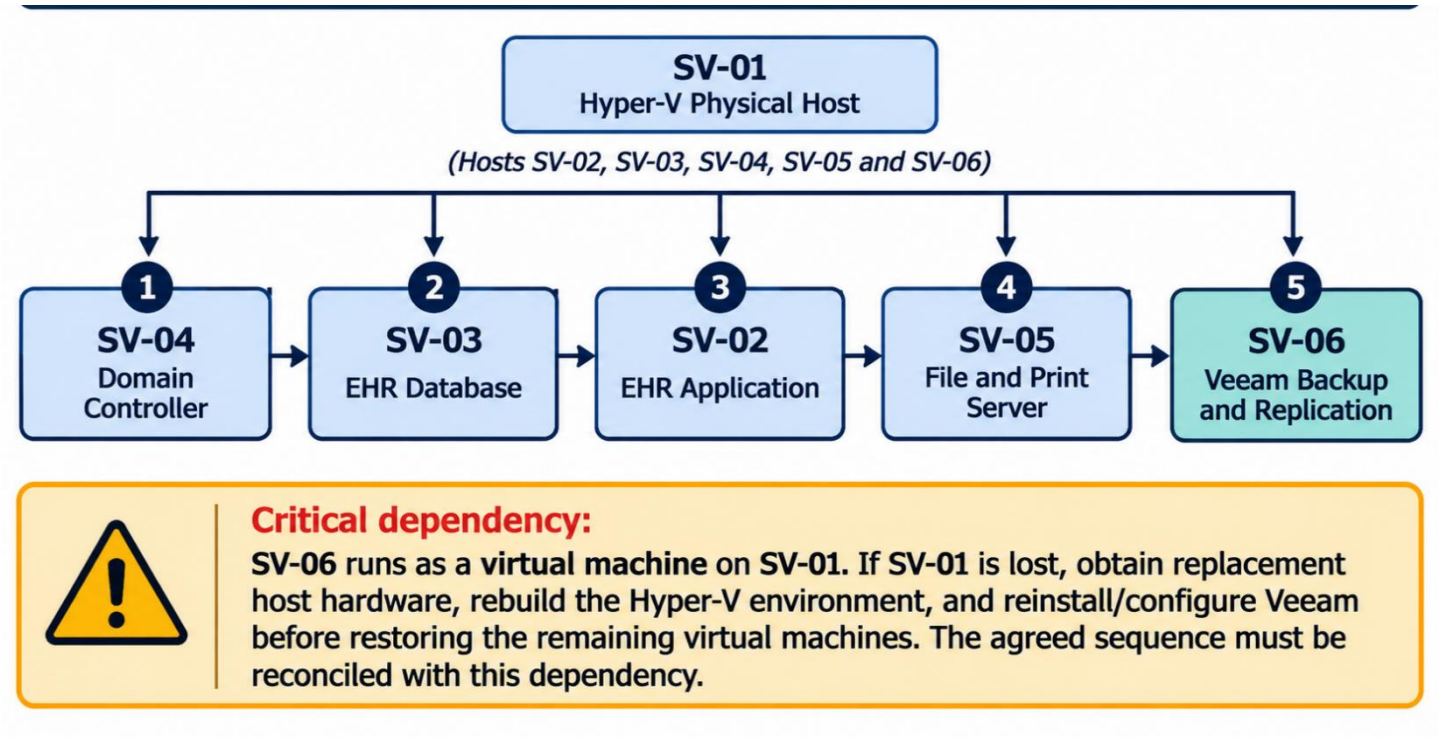


Figure 7.3: **Proposed Server Recovery Dependencies**

CHAPTER EIGHT
COSTED 90-DAY CYBERSECURITY IMPROVEMENT ROADMAP

8.1 Roadmap Overview

This chapter presents the proposed 90-day cybersecurity improvement roadmap for the simulated healthcare provider.

The roadmap translates the findings of the current-state assessment, cybersecurity risk register, target security architecture and Operation DryRUN tabletop exercise into prioritised implementation activities.

The programme is divided into three implementation phases, each covering approximately 30 days.

8.2 Implementation Phases

8.2.1 Phase One: Stabilise and Assign (Days 1–30)

The first phase addresses critical security exposures and establishes ownership of priority remediation activities.

Key activities include:

1. Remove direct internet-facing RDP port-forwarding.
2. Enforce MFA for priority accounts and remote access.
3. Isolate backup storage credentials from routine domain administration.
4. Issue physical clinical downtime and emergency contact packs.
5. Review privileged accounts and resolve orphaned SIDs.
6. Establish a Windows Server 2016 migration plan.
7. Assign risk owners and confirm baseline risk scores.

Expected Deliverables:

- Approved remote access restrictions.
- Priority MFA enforcement report.
- Backup isolation configuration record.
- Updated privileged account register.
- Emergency contact and downtime packs.
- Approved server migration plan.

8.2.2 Phase Two: Visibility and Verification (Days 31–60)

The second phase strengthens endpoint security, monitoring capabilities and internal network controls.

Key activities include:

1. Deploy Microsoft Defender for Business for eligible user endpoints.
2. Establish appropriate server endpoint protection coverage.
3. Deploy centralised log collection through Wazuh or an equivalent SIEM platform.
4. Implement VLAN-based network segmentation across `Z1`–`Z7`.
5. Replace shared vendor accounts with individually attributable accounts.
6. Introduce structured RBAC reviews.
7. Conduct the first timed synthetic restoration exercise.

Expected Deliverables:

- Endpoint protection deployment report.
- Central monitoring configuration.

- Network segmentation implementation record.
- Third-party access register.
- Access review report.
- First restoration test report.

8.2.3 Phase Three: Prove and Embed (Days 61–90)

The third phase focuses on validating improvements and establishing sustainable security governance.

Key activities include:

1. Complete the Windows Server migration for affected systems.
2. Complete the priority Windows endpoint modernisation programme.
3. Execute a follow-up recovery dependency test.
4. Conduct a second ransomware tabletop exercise.
5. Reassess residual risks.
6. Establish monthly management dashboard reporting.
7. Review and update the incident response playbook.
8. Obtain management approval for outstanding risk treatment actions.

Expected Deliverables:

- Server migration completion report.
- Endpoint remediation reconciliation.
- Recovery validation report.
- Updated risk register.
- Second tabletop exercise report.
- Day 90 management dashboard.

8.3 Costing Model and Financial Summary

The implementation budget is expressed in Nigerian Naira (₦).

The figures represent planning estimates as at 4 November 2026 and are subject to supplier quotations, licensing confirmation, procurement conditions and foreign-exchange fluctuations.

A 15% contingency has been included in the cash requirement.

8.3.1 Financial Summary by Cost Category

Table 8.1: 90-Day Roadmap Financial Summary

Cost Category	Phase 1 (₦)	Phase 2 (₦)	Phase 3 (₦)	Total (₦)
External Technical Support (MSP)	750,000	1,800,000	1,050,000	3,600,000
Tools and Software Licensing	2,430,000	5,910,000	2,970,000	11,310,000
Infrastructure and Hardware	5,990,000	1,600,000	0	7,590,000
Training and Exercise Facilitation	250,000	400,000	150,000	800,000
Cash Subtotal	**9,420,000**	**9,710,000**	**4,170,000**	**23,300,000**

8.3.2 Contingency and Full Economic Cost

Financial Component	Amount
Cash Subtotal	₦23,300,000
Contingency (15%)	₦3,495,000
Total Estimated Cash Requirement	**₦26,795,000**
Absorbed Internal Labour Valuation	₦3,600,000
Total Full Economic Cost	**₦30,395,000**

The contingency is calculated as:

₦23,300,000 × 15% = ₦3,495,000.

The full economic cost includes the cash requirement and the estimated value of internal labour. Internal labour is not an additional cash procurement expense unless separately contracted or paid.

8.3.3 Annual Recurring Software Licensing Schedule

Table 8.2: Annual Recurring Software Licensing Schedule

Software or Service	Proposed Coverage	Annual Estimate
Microsoft Entra ID P1	25 priority users	₦2,430,000
Microsoft Defender for Business	70 users and proposed server protection coverage	₦5,100,000
Password Vault Subscription	10 seats	₦810,000
Total		**₦8,340,000**

The annual subscription schedule is a recurring operating-cost estimate and should be distinguished from the 90-day implementation cash requirement.

The Defender licensing line requires confirmation of the appropriate server licensing and product eligibility. The 70-user and seven-server coverage must not be assumed to be included under a user-only licence without verification.

8.4 Financial Assumptions and Limitations

The financial model is based on the following assumptions:

1. The listed costs are planning estimates, not verified supplier quotations.
2. Software licensing is subject to current product eligibility and licensing terms.
3. Foreign-exchange movements may affect imported technology costs.
4. The 15% contingency is applied to the cash subtotal.
5. Internal labour is valued separately to show the full economic cost.
6. Recurring software subscriptions may continue beyond the initial 90-day implementation period.
7. Infrastructure procurement must be supported by technical specifications and competitive supplier quotations.

Before implementation, management should approve the detailed itemised budget in Appendix G.

8.5 Chapter Summary

The 90-day roadmap provides a phased approach for addressing critical security exposures, improving security visibility and validating recovery capabilities.

The estimated cash requirement is ₦26,795,000, while the full economic cost, including absorbed internal labour, is ₦30,395,000.

The roadmap provides management with a structured implementation sequence and financial basis for prioritising ransomware resilience improvements.

CHAPTER NINE
CYBERSECURITY AND RECOVERY READINESS MANAGEMENT DASHBOARD

9.1 Dashboard Governance

The management dashboard provides a structured mechanism for monitoring cybersecurity improvement activities, control coverage and operational recovery readiness across the 90-day programme.

The Head of IT is responsible for maintaining the technical performance data, while the Medical Director reviews the reported indicators during monthly management meetings and implementation phase gates.

The dashboard uses 12 key performance indicators (`KPI 1–KPI 12`) to measure progress against agreed targets.

9.2 Key Performance Indicators

Table 9.1: Management Dashboard Key Performance Indicators

KPI	Performance Indicator	Baseline	Day 30	Day 60	Day 90	Data Source
KPI 1	Critical and High Asset Records Completed	100%	100%	100%	100%	Asset Register Workbook
KPI 2	Privileged Accounts Reviewed and Hardened	0%	100%	100%	100%	AD Privileged Audit Log
KPI 3	Priority Accounts Protected by MFA	10%	50%	80%	100%	Entra ID MFA Enforcement Report
KPI 4	Endpoints Supported and Fully Patched	68%	75%	85%	95%	Endpoint Management Compliance Report
KPI 5	Scheduled Backup Jobs Completed Successfully	Not Reported	95%	98%	98%	Veeam Daily Backup Logs
KPI 6	Planned Restoration Tests Completed	0%	0%	50%	100%	Timed Restore Execution Reports
KPI 7	Priority Alerts Reviewed Within 24 Hours	0%	0%	50%	95%	Wazuh SIEM Incident Register
KPI 8	Implementation Roadmap Actions On Schedule	0%	80%	85%	90%	Action Register Tracker
KPI 9	Staff Completing Ransomware Training	0%	60%	90%	90%	HR Attendance Records
KPI 10	Third-Party Accounts with Approved Scope	0%	0%	100%	100%	Vendor Governance Register
KPI 11	Laboratory Synthetic Restore Duration	Not Measured	N/A	≤8 Hours	≤6 Hours	Timed Restore Audit Record
KPI 12	Unresolved High and Critical Risks	15 (Preliminary)	12	8	≤4	Updated Risk Register

The targets represent proposed management performance thresholds.

9.3 KPI Measurement and Interpretation

KPI 1: Critical and High Asset Records Completed

Measures the percentage of identified critical and high-priority asset records containing the required information, ownership and classification details.

KPI 2: Privileged Accounts Reviewed and Hardened

Measures the proportion of identified privileged accounts that have undergone access review and the required hardening activities.

KPI 3: Priority Accounts Protected by MFA

Measures the percentage of designated priority accounts covered by enforced multi-factor authentication.

KPI 4: Endpoints Supported and Fully Patched

Measures the proportion of in-scope endpoints operating supported software versions and meeting the approved patch compliance standard.

KPI 5: Scheduled Backup Jobs Completed Successfully

Measures the proportion of scheduled backup jobs completed successfully within the reporting period.

KPI 6: Planned Restoration Tests Completed

Measures the proportion of scheduled restoration tests completed with documented validation results.

KPI 7: Priority Alerts Reviewed Within 24 Hours

Measures the percentage of priority security alerts reviewed and appropriately documented within 24 hours of generation.

KPI 8: Implementation Roadmap Actions On Schedule

Measures the proportion of implementation actions completed by their approved milestone dates.

KPI 9: Staff Completing Ransomware Training

Measures the percentage of designated employees who complete the approved ransomware awareness training programme.

KPI 10: Third-Party Accounts with Approved Scope

Measures the percentage of active third-party accounts with documented ownership, access scope and approval.

KPI 11: Laboratory Synthetic Restore Duration

Measures the elapsed time required to complete an approved synthetic restoration exercise.

This indicator measures laboratory recovery performance and should not be represented as proof that the organisation can restore its entire production environment within the same timeframe.

KPI 12: Unresolved High and Critical Risks

Measures the number of risks remaining in the High or Critical categories after documented likelihood and impact reassessment.

9.4 Mandatory Data-Quality Qualifications

9.4.1 Endpoint Remediation Reconciliation

The baseline identifies 21 unsupported Windows 10 PCs out of 66.

The improvement plan proposes upgrading 12 PCs and replacing six PCs, giving a total of 18 planned remediation actions.

This leaves three devices requiring a documented decision.

The endpoint remediation target is therefore provisional pending final device eligibility verification, procurement reconciliation and updated inventory records.

9.4.2 Preliminary Risk Count Baseline

The initial count of 15 represents the complete preliminary risk register (`R01–R15`).

It must not automatically be interpreted as 15 formally confirmed High or Critical risks.

A formal likelihood and impact reassessment during Phase 1 must establish the confirmed starting number of High and Critical risks before reduction percentages are reported.

9.4.3 KPI Evidence Requirements

Every reported KPI value must be supported by:

- Reporting date.
- Data source.
- Measurement formula.
- Responsible owner.
- Supporting evidence.
- Explanation of any missing or incomplete data.

9.5 Management Reporting and Escalation

The dashboard should be reviewed at the end of each implementation phase.

Management attention should be prioritised where:

1. Critical security actions are overdue.
2. Backup jobs fail or restoration tests are unsuccessful.
3. MFA enforcement remains below the approved target.
4. High or Critical risks remain untreated.
5. Endpoint remediation falls behind the approved schedule.
6. Incident response and communication arrangements remain incomplete.

Unresolved critical issues should be escalated to the Medical Director and appropriate management stakeholders.

9.6 Chapter Summary

The 12-indicator dashboard provides a structured mechanism for tracking cybersecurity improvement progress and recovery readiness.

Its effectiveness depends on accurate data collection, documented measurement methods and management review.

The dashboard should be maintained as a living governance document throughout the implementation programme.

CHAPTER TEN
CONCLUSION AND RECOMMENDATIONS

10.1 Project Synthesis

This consultancy project examined the cybersecurity risks and ransomware resilience requirements of a simulated Nigerian multi-site healthcare provider operating across FAC-A and FAC-B.

The assessment identified potential exposure arising from flat network connectivity, uncontrolled remote management access, excessive administrative privileges, insufficient endpoint protection, limited security monitoring and backup infrastructure dependencies.

Using NIST CSF 2.0 as the primary assessment framework, the project established a 50-record asset inventory, a canonical register of 15 cybersecurity risks and a proposed security architecture across seven technical domains.

The practical laboratory activities demonstrated selected access control, security auditing and data restoration capabilities. The RBAC exercise achieved nine expected access decisions, the process auditing exercise confirmed Windows Event ID 4688 generation, and the backup restoration exercise produced matching SHA-256 checksums for three synthetic files.

Operation DryRUN provided a discussion-based assessment of incident response readiness, identifying procedural gaps and corrective actions for integration into the improvement programme.

The project also developed a costed 90-day implementation roadmap and a 12-indicator management dashboard to support management oversight and prioritised execution.

Collectively, these deliverables establish a structured approach for improving ransomware resilience and supporting the continuity of essential healthcare services.

10.2 Summary of Priority Recommendations

1. Strengthen Remote Access Protection

Remove all direct internet-facing RDP port-forwarding rules as an immediate priority.

Implement approved VPN or zero-trust remote access arrangements with mandatory MFA, access restrictions and session logging.

2. Harden Privileged Accounts

Terminate routine operational use of domain administrator accounts.

Introduce dedicated administrative accounts, resolve orphaned SIDs, review privileged group membership and enforce least-privilege access.

3. Isolate and Protect Backup Infrastructure

Remove backup repositories from unnecessary domain dependencies where technically feasible.

Enforce dedicated backup administration credentials, incorporate FAC-B NAS (`ST-01`) into protected backup arrangements and maintain verified offline or immutable copies.

4. Modernise Endpoints and Servers

Upgrade eligible Windows 10 devices, replace non-upgradeable legacy hardware and implement centralised endpoint protection.

Complete the planned Windows Server 2016 migration before its extended support termination date of 12 January 2027.

5. Improve Security Monitoring

Deploy centralised Wazuh monitoring alongside appropriate endpoint protection.
Prioritise monitoring of process creation (`4688`), failed logons (`4625`), local security group modifications (`4732`) and suspicious backup administration activity.

6. Strengthen Third-Party Governance

Replace shared vendor credentials with individually attributable accounts.
Require documented access approvals, MFA, access expiry dates and session monitoring.

7. Formalise Incident Response and Recovery

Adopt the proposed incident response playbook, distribute emergency contact cards at both facilities and establish clearly defined authority for containment and service restoration.
Conduct regular tabletop exercises and restoration tests.

8. Establish Continuous Management Oversight

Maintain the 12-KPI management dashboard, update the cybersecurity risk register and review outstanding remediation activities during monthly management meetings.

10.3 Final Recommendation

Management should approve the phased 90-day cybersecurity improvement roadmap and prioritise immediate treatment of the critical risks relating to remote access, privileged account compromise, network segmentation and backup infrastructure exposure.

The implementation programme should be supported by clearly assigned responsibilities, verified technical evidence, appropriate procurement controls and regular management review.

10.4 Final Conclusion

Cybersecurity resilience in healthcare requires more than the deployment of security tools. It depends on the coordinated management of people, processes, technology, information and recovery capabilities.

The proposed strategy provides the simulated healthcare provider with a practical foundation for improving security governance, protecting sensitive information, detecting malicious activity, responding to ransomware incidents and restoring essential services.

Although the project does not certify the security posture of an actual healthcare organisation, its assessment methodology, laboratory demonstrations, risk treatment recommendations and implementation roadmap provide a structured consultancy model that can be adapted for an appropriately authorised real-world healthcare environment.

REFERENCES

Bartock, M., Cichonski, J., Souppaya, M., Smith, M., Witte, G., & Scarfone, K. (2016). *Guide for cybersecurity event recovery* (NIST Special Publication 800-184). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-184

Cybersecurity and Infrastructure Security Agency. (2023). *#StopRansomware guide*. https://www.cisa.gov/resources-tools/resources/stopransomware-guide

Fisher, W., Souppaya, M., Barker, W., & Kent, K. (2026). *Ransomware risk management: A Cybersecurity Framework 2.0 community profile* (NIST Interagency Report 8374, Rev. 1). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.IR.8374r1

Microsoft. (n.d.). *Windows 10 reaching end of support*. Microsoft Learn. Retrieved November 4, 2026, from https://learn.microsoft.com/en-us/lifecycle/announcements/windows-10-end-of-support

Microsoft. (n.d.). *Windows Server 2016*. Microsoft Learn. Retrieved November 4, 2026, from https://learn.microsoft.com/en-us/lifecycle/products/windows-server-2016

National Institute of Standards and Technology. (2012). *Guide for conducting risk assessments* (NIST Special Publication 800-30, Rev. 1). https://doi.org/10.6028/NIST.SP.800-30r1

National Institute of Standards and Technology. (2020a). *Data integrity: Detecting and responding to ransomware and other destructive events* (NIST Special Publication 1800-26). https://www.nccoe.nist.gov/publication/1800-26/

National Institute of Standards and Technology. (2020b). *Data integrity: Identifying and protecting assets against ransomware and other destructive events* (NIST Special Publication 1800-25). https://www.nccoe.nist.gov/publication/1800-25/

National Institute of Standards and Technology. (2020c). *Data integrity: Recovering from ransomware and other destructive events* (NIST Special Publication 1800-11). https://www.nccoe.nist.gov/publication/1800-11/

National Institute of Standards and Technology. (2020d). *Security and privacy controls for information systems and organizations* (NIST Special Publication 800-53, Rev. 5). https://doi.org/10.6028/NIST.SP.800-53r5

National Institute of Standards and Technology. (2020e). *Zero trust architecture* (NIST Special Publication 800-207). https://doi.org/10.6028/NIST.SP.800-207

National Institute of Standards and Technology. (2024). *The NIST Cybersecurity Framework (CSF) 2.0* (NIST Cybersecurity White Paper 29). https://doi.org/10.6028/NIST.CSWP.29

Nelson, A., Rekhi, S., Souppaya, M., & Scarfone, K. (2025). *Incident response recommendations and considerations for cybersecurity risk management: A CSF 2.0 community profile* (NIST Special Publication 800-61, Rev. 3). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-61r3

Neprash, H. T., McGlave, C. C., Cross, D. A., Virnig, B. A., Puskarich, M. A., Huling, J. D., Rozenshtein, A. Z., & Nikpay, S. S. (2022). Trends in ransomware attacks on US hospitals, clinics, and other health care delivery organizations, 2016–2021. *JAMA Health Forum, 3*(12), Article e224873. https://doi.org/10.1001/jamahealthforum.2022.4873

Nigeria Data Protection Act, 2023, Act No. 37 of 2023 (Nigeria). https://ndpc.gov.ng/

APPENDIX A: INDIVIDUAL CONTRIBUTION RECORDS

A.1 Team Workstream Summary

This appendix documents the allocation of responsibilities and individual contributions to the consultancy capstone project.

Team Member	Registration Number	Individual Contribution
Alphonsus Stephen Chibuike	C11/26/CSCC/17451	Project leadership, charter creation, governance coordination and final report consolidation
Laban Emmanuel Rakum	C11/26/CSCC/17472	50-asset inventory development, NIST CSF 2.0 Current and Target profiling, and baseline gap analysis
Nicholas Atacha	C11/26/CSCC/17395	Canonical risk register (`R01–R15`), likelihood and impact scoring, and risk treatment recommendations
Oreofe Dada	C11/26/CSCC/17383	Target security architecture across seven domains and seven-zone network model
Owiliwa Clever Goodluck	C11/26/CSCC/17416	Isolated laboratory setup, RBAC permission testing, process auditing and SHA-256 backup restoration verification
Oyewale Akinrinde	C11/26/CSCC/17529	Incident response playbook, Operation DryRUN tabletop exercise, 90-day roadmap and 12-KPI dashboard

A.2 Collaborative Responsibilities

All members contributed to the development and review of the consultancy deliverables within their respective workstreams.

The Team Lead coordinated the integration of individual submissions into a unified report and maintained consistency across project identifiers, technical references and final documentation.

APPENDIX B: MASTER EVIDENCE REGISTER

B.1 Purpose

This appendix establishes a central evidence register to support traceability across the cybersecurity assessment, technical architecture, laboratory demonstrations, incident response and implementation planning.

All evidence items use standardised identifiers and should be maintained with appropriate version control.

B.2 Evidence Register

Evidence ID	Domain	Evidence Description	Source File / Artifact
ASSET-E-001	Asset Baseline	50-Asset Master Inventory Workbook	`Asset_Inventory_v1.xlsx`
ARCH-E-001	Architecture	Target Network Zoning Diagram (`Z1–Z7`)	`Target_Architecture_v1.vsdx`
LAB-E-015	Laboratory	Process Command-Line Audit Screenshot	`lab_proc_audit.png`
LAB-E-016	Laboratory	Process Auditing Registry Enablement Output	`lab_reg_audit.png`

LAB-E-017	Laboratory	Password Policy Baseline Configuration Output	`lab_pass_pol.txt`
LAB-E-018	Laboratory	Failed Authentication Security Log Review	`lab_event_4625.evtx`
LAB-E-019	Laboratory	Successful File Access Audit Log (`Event ID 4663`)	`lab_event_4663.evtx`
LAB-E-020	Laboratory	File System Audit SACL Verification Record	`lab_sacl_config.txt`
LAB-E-021	Laboratory	Synthetic Data Restore SHA-256 Hash Comparison	`restore_hash_verify.ps1`
DRYRUN-E-001	Incident Response	Operation DryRUN Tabletop Exercise Record	`DryRUN_Report_Final.pdf`
ROADMAP-E-001	Implementation	90-Day Costing and Financial Schedule	`Roadmap_Budget_v1.xlsx`
ROADMAP-E-002	Governance	Management Dashboard 12-KPI Template	`Dashboard_KPI_v1.xlsx`

B.3 Evidence Management Requirements

Each evidence item should retain:

1. Unique evidence identifier.
2. Original source filename.
3. Evidence description.
4. Date of creation or collection.
5. Responsible contributor.
6. Relevant chapter or appendix reference.
7. Version and verification status.

Evidence should be retained in its original form wherever possible. Any edited screenshots or exported records must be clearly identified as derivatives of the original evidence.

APPENDIX C: LABORATORY TECHNICAL EVIDENCE

C.1 Purpose

This appendix contains the technical artifacts supporting the laboratory demonstrations described in Chapter Six.

The evidence provides supporting material for the local access control, process auditing and backup restoration exercises.

C.2 Laboratory Scripts and Artifacts

C.2.1 RBAC Test Script

Filename: `RBAC_Test_Script.ps1`

Purpose:

- Create or configure local test accounts.

- Establish folder-level NTFS DACLs.
- Assign role-specific permissions.
- Execute automated permission verification.
- Record expected and actual access decisions.

C.2.2 Process Auditing Setup

Filename: `Process_Audit_Setup.cmd`

Purpose:

- Configure Windows process-creation auditing.
- Enable command-line logging.
- Support verification of Event ID 4688 generation.

C.2.3 Backup Hash Validation Script

Filename: `Backup_Hash_Validation.ps1`

Purpose:

- Generate synthetic source files.
- Calculate original SHA-256 checksums.
- Copy source files into the backup directory.
- Simulate source directory unavailability.
- Restore backup copies.
- Calculate restored file hashes.
- Compare original and restored cryptographic values.

C.3 Evidence Reconciliation

The final laboratory evidence package should include the original scripts, command outputs, relevant screenshots and complete hash verification records.

Where the evidence register lists an event export or configuration file that is not reproduced in Chapter Six, the corresponding artifact should remain in this appendix or the supporting submission package.

APPENDIX D: CONSOLIDATED CYBERSECURITY RISK REGISTER

D.1 Purpose

This appendix provides the detailed supporting risk assessment matrix for the 15 canonical cybersecurity risks identified in Chapter Four.

D.2 Required Risk Register Fields

Each risk record must include:

Field	Description
Risk ID	Unique identifier (`R01–R15`)

Risk Title	Concise risk description
Threat Source	Potential source of the threat
Threat Event	Event that could exploit the exposure
Vulnerability	Weakness that could be exploited
Affected Assets	Relevant asset identifiers
Existing Controls	Controls documented in the baseline
Inherent Likelihood	Score from 1–5
Inherent Impact	Score from 1–5
Inherent Risk Score	Likelihood × Impact
Risk Rating	Low, Moderate, High or Critical
Proposed Treatment	Recommended mitigation or other treatment
Risk Owner	Accountable role
Residual Likelihood	Expected likelihood after treatment
Residual Impact	Expected impact after treatment
Residual Risk Score	Residual likelihood × residual impact
Treatment Status	Open, In Progress, Implemented or Accepted

D.3 Risk Register Governance

The risk register must remain the authoritative source for all risk references in the report.

Risk identifiers must not be changed between chapters, tables, architecture documents, incident response records and dashboard reports.

Numerical risk scores must be populated from the approved risk assessment workbook. No missing likelihood, impact or residual values should be reconstructed without supporting assessment evidence.

APPENDIX E: SECURITY ARCHITECTURE AND NETWORK-ZONE DESIGN

E.1 Purpose

This appendix provides the logical network segmentation design supporting the target security architecture described in Chapter Five.

The design separates the organisation's critical technology resources into seven security zones.

E.2 Network-Zone Definitions

Zone	Description	Proposed Subnet
Z1	Clinical and User Workstation Subnet	`10.10.10.0/24`
Z2	Clinical Application Subnet	`10.10.20.0/24`
Z3	Shared Storage and File Server Subnet	`10.10.30.0/24`
Z4	Infrastructure and Active Directory Management Subnet	`10.10.40.0/24`

Z5	Isolated Backup Storage Subnet	10.10.50.0/24
Z6	Perimeter Gateway and SSL-VPN DMZ	172.16.10.0/29
Z7	Isolated Guest Wi-Fi Subnet	192.168.100.0/24

E.3 Network Security Principles

The proposed network architecture adopts the following principles:

1. Default-deny traffic between security zones.
2. Explicitly approved communication between business-critical systems.
3. Restricted administrative access to infrastructure management resources.
4. Isolation of backup repositories from ordinary user networks.
5. Separation of guest wireless devices from internal healthcare systems.
6. Controlled remote access through approved gateways.
7. Centralised monitoring of inter-zone network activity.

The proposed subnets are logical design allocations and require validation against the actual addressing plan, routing environment and network equipment before implementation.

APPENDIX F: OPERATION DRYRUN TABLETOP EXERCISE

F.1 Exercise Overview

Exercise Name: Operation DryRUN
Exercise Date: 28 October 2026
Exercise Type: Discussion-Based Tabletop Exercise
Scenario: RDP compromise resulting in EHR encryption across FAC-A and FAC-B.

F.2 Exercise Documentation

The supporting exercise report contains:

A. Participant Attendance Roster

Eleven participants representing Executive Management, IT, Clinical Operations and Managed Service Provider roles.

B. Scenario Inject Logs

Six sequential scenario injects tracking incident progression from initial access and remote compromise to EHR encryption and ransom demand.

C. Detailed Gap Matrix

Ten identified operational gaps, designated G1–G10, with corresponding risk references.

D. Corrective Action Plan

Eight corrective actions, designated R1–R8, with assigned owners, implementation priorities and roadmap milestones.

F.3 Exercise Governance

The exercise findings should be maintained in the original tabletop report and action tracker.

The detailed records must be reconciled with Chapter Seven before final submission, particularly where the summary report does not list all ten gaps or all eight corrective actions.

APPENDIX G: COSTED ROADMAP AND MANAGEMENT DASHBOARD

G.1 Purpose

This appendix contains the detailed implementation costing and performance measurement documentation supporting Chapters Eight and Nine.

G.2 Financial Supporting Worksheets

The roadmap workbook should contain:

1. Itemised software licensing estimates.
2. Hardware and infrastructure procurement estimates.
3. Managed Service Provider daily rates.
4. Internal labour valuation assumptions.
5. Training and exercise facilitation costs.
6. Phase-based expenditure allocations.
7. Contingency calculations.
8. Annual recurring subscription schedule.

The supplied planning assumptions include:

- MSP daily rate: ₦150,000.
- Internal labour valuation: ₦40,000 per day.
- Contingency: 15% of the cash subtotal.

G.3 Management Dashboard

The management dashboard workbook supports the 12 KPIs identified in Chapter Nine.

Each KPI should contain:

- Indicator name.
- Baseline value.
- Target value.
- Actual reported value.
- Measurement date.
- Data source.
- Responsible owner.
- Performance status.
- Supporting evidence reference.

G.4 Financial Reconciliation

The financial workbook must reconcile the phase-based cash subtotal of ₦23,300,000, the 15% contingency of ₦3,495,000 and the resulting cash requirement of ₦26,795,000.

The annual subscription estimate of ₦8,340,000 and absorbed internal labour valuation of ₦3,600,000 must be separately identified to prevent double counting.

APPENDIX H: PROJECT ASSUMPTIONS, LIMITATIONS AND VALIDATION RECORD

H.1 Purpose

This appendix documents the assumptions, exclusions, academic limitations and validation qualifications governing the consultancy engagement.

H.2 Project Assumptions

The project is based on the following scenario assumptions:

1. The case organisation is a simulated Nigerian private healthcare provider.
2. The organisation operates two facilities, FAC-A and FAC-B.
3. The organisation employs approximately 80 staff members.
4. Its essential services depend on EHR, patient registration, billing, communication and administrative systems.
5. Its representative infrastructure includes servers, network equipment, endpoints and backup resources.
6. The technology environment described in the baseline represents the approved assessment scenario.
7. Laboratory activities use synthetic information and isolated testing resources.

H.3 Project Limitations

The project is subject to the following limitations:

- No production healthcare infrastructure was assessed directly.
- No real patient data was accessed.
- No live ransomware or destructive malware was deployed.
- Laboratory results cannot establish enterprise-wide security effectiveness.
- Some scenario parameters require further technical validation.
- Financial estimates are planning figures rather than confirmed procurement quotations.
- Risk scores remain subject to final numerical reconciliation.
- Endpoint remediation figures require confirmation against the detailed device register.

H.4 Validation Record

Validation Area	Current Status	Required Follow-Up
50-Asset Inventory	Baseline established	Confirm all detailed asset records
CIA Assessment	Criticality categories identified	Reconcile individual C, I and A scores
Risk Register	15 canonical risks identified	Verify numerical inherent and residual scores
Security Architecture	Seven-zone model proposed	Validate network addressing and firewall rules
RBAC Demonstration	9/9 expected access decisions achieved	Retain original execution evidence
Process Auditing	Event ID 4688 demonstrated	Retain original event record
Backup Restoration	3/3 synthetic files verified	Include complete SHA-256 values
Operation DryRUN	Exercise conducted	Reconcile all ten gaps and eight actions

Financial Roadmap	₦26,795,000 estimated cash requirement	Verify supplier quotations and licensing
Management Dashboard	12 indicators defined	Establish dated baseline measurements

H.5 Final Validation Statement

The consultancy deliverable is based on a simulated organisational environment and controlled academic laboratory exercises.

Its findings, technical demonstrations and recommendations must be interpreted within those boundaries.

The report provides a structured assessment and improvement model rather than a certification of operational cybersecurity effectiveness or regulatory compliance.